

ENTERPRISE AI HANDBOOK SERIES

2

ENTERPRISE AI GOVERNANCE HANDBOOK

Policies • Controls • Risk Classification • Compliance



STRATEGY. GOVERNANCE. OPERATIONS.

HAROLD WEBB, PhD

ENTERPRISE AI GOVERNANCE HANDBOOK

A Practical Guide for Managers and Leaders

Corporate Edition — Full Enterprise Manual

Version 1.0 — May 2026

Harold Webb, PhD

*Associate Professor Emeritus of Information and Technology Management at The University of Tampa's
John H. Sykes College of Business.*

Enterprise AI Handbook Series — Volume 2

[NIST AI RMF 1.0](#) • [EU AI Act \(2024/1689\)](#) • [ISO/IEC 42001:2023](#) • [OECD AI Principles](#)

Prompts and research created using Claude (Anthropic) and ChatGPT (OpenAI).

Results cross-checked between systems.

Research current through March 2026

Copyright and Edition Information

© 2026 Harold Webb, PhD. All rights reserved except as expressly permitted under Creative Commons.

Edition: Version 1.0 — May 2026. First edition. A change log is maintained at the end of this document.

License: Released under Creative Commons Attribution-NonCommercial 4.0 International (CC BY-NC 4.0). <https://creativecommons.org/licenses/by-nc/4.0/>

Suggested citation: Webb, H. (May 2026). Enterprise AI Governance Handbook: A Practical Guide for Managers and Leaders. Enterprise AI Handbook Series, Volume 2. Zenodo. <https://doi.org/10.5281/zenodo.20328823>

Zenodo DOI: [10.5281/zenodo.20328823](https://doi.org/10.5281/zenodo.20328823) (The Zenodo edition is deposited under a Creative Commons Attribution-NonCommercial 4.0 International (CC BY-NC 4.0) license.)

Rights and permissions

The scholarly edition deposited on Zenodo is released under CC BY-NC 4.0, which permits sharing and adaptation with appropriate credit. Readers who require text for non-commercial scholarly or educational purposes are directed to the Zenodo edition.

Legal disclaimer

This handbook provides reference material for enterprise AI governance practitioners. It is not legal, financial, accounting, tax, or medical advice, and it does not constitute an opinion on the law of any jurisdiction. Readers should consult qualified counsel, licensed professionals, or regulatory authorities before making compliance, contractual, procurement, deployment, or regulatory decisions based on the frameworks, case studies, or checklists described here.

Case study disclaimer

Case studies drawn from public reporting are used for analytical and educational purposes. No statement about any real company, product, court proceeding, regulator, or individual is intended as a legal conclusion about that party or as an assertion of fact beyond what has been publicly reported in the cited sources.

Trademarks

Product and company names mentioned in this work may be trademarks of their respective owners. Use of these names is for identification and descriptive purposes only and does not imply endorsement.

Contact

ORCID 0009-0006-2002-2209 or email hwebb@ut.edu

About This Handbook

This handbook provides managers and senior leaders with a practical framework for enterprise AI governance. It synthesizes four authoritative international frameworks — NIST AI RMF 1.0, EU AI Act (2024/1689), ISO/IEC 42001:2023, and OECD AI Principles — into an operational governance program with actionable templates, decision frameworks, and compliance tools.

The author's Preface to the Enterprise AI Handbook Series, describing the origin, methodology, and intended use of this work, appears in the Series Executive Summary and in Volume 1 (Strategic Opportunity & Risk Analysis).

Each section follows a consistent structure: regulatory foundation, operational guidance, business example from a named enterprise, and a "Why It Matters" block written for managers. The block explains the business consequences of getting governance right — or wrong.

About This Volume

This handbook provides managers, senior leaders, risk officers, compliance personnel, legal counsel, IT leaders, and board members with a practical enterprise AI governance framework. It synthesizes NIST AI RMF 1.0, the EU AI Act, ISO/IEC 42001:2023, and OECD AI Principles into operational guidance, including governance structures, policy frameworks, risk classification, controls, monitoring, prompt governance, audit, board reporting, and continuous improvement. Requirements are classified as mandated, recommended, or emerging practice to support management use, audit preparation, and compliance planning.

The statement classification system

This handbook applies explicit statement classifications throughout. Every governance requirement is marked with one of three labels to indicate its obligatory status:

Label	Meaning
MANDATED	Required by binding law or regulation (e.g., EU AI Act, GDPR). Non-compliance creates direct legal liability.
RECOMMENDED	Prescribed by authoritative voluntary frameworks (NIST AI RMF, ISO/IEC 42001, OECD). Not legally required but reflects accepted best practice; may be assessed in audit or procurement.
EMERGING PRACTICE	Observed in leading enterprises; not yet universally adopted or standardized. Adoption varies by organization, sector, and jurisdiction.

Author and AI-tooling acknowledgment

This handbook was authored by Harold Webb, PhD. The author's role was scope definition, framework selection, case-study curation, statement classification assignment, domain-specific editorial judgment, verification, and final approval of every claim and citation in this volume.

Research, drafting, and structural design were assisted by two large language model systems — Claude (Anthropic) and ChatGPT (OpenAI). AI tools were used to draft prose, generate initial table structures, cross-check factual claims between systems, and identify gaps. AI-generated

drafts were then reviewed, revised, verified against primary sources, and approved by the author. No claim, citation, or figure in this handbook was accepted on the basis of AI generation alone; the statement classification system documents the obligatory status for every governance requirement.

Examples and Case Illustrations

The examples used throughout this volume — including the medium-sized firm reference case, illustrative staffing structures, tooling selections, cost estimates, and AI personnel requirements — are provided for demonstration and educational purposes only. They are not a recommended configuration for any specific organization. Organizations planning actual AI deployments must develop requirements based on their own strategy, management intent, available resources, workforce composition, regulatory environment, industry-specific compliance obligations, and risk tolerance. Pricing, vendor offerings, regulatory frameworks, model capabilities, and standards in AI are evolving rapidly; readers must verify current information at the time of any actual planning, procurement, or implementation decision. The epistemic labels applied throughout this volume (VERIFIED, SYNTHESIS, INFERENCE, DATA GAP, SPECULATION, COMPOSITE) identify the evidentiary basis of each claim and should be used to inform how a given example or estimate is applied to local conditions.

Companion volumes

This handbook is designed for enterprise-scale governance programs. Organizations at different scales or stages of AI adoption may benefit from the following companion volumes in the Enterprise AI Handbook Series:

- **AI for Small Business: Scaling the Enterprise AI Handbook to Solo and Micro-Team Operators** — Adapts the governance frameworks in this handbook for organizations without dedicated compliance, legal, or AI governance staff. Provides simplified governance checklists, risk classification tools, and policy templates calibrated to small business resources and regulatory exposure.
- **Enterprise AI Systems — Organizational Maturity Analysis: Staffing, Costs, Risks, Critical Success Factors** — Provides the workforce planning, cost modeling, and organizational readiness assessment that complements the governance program design in this handbook. Use this companion for budgeting governance program implementation and for assessing organizational readiness at each maturity level.
- **Enterprise AI Systems — Personnel & Tooling Handbook** — Provides detailed guidance on AI personnel roles, competency frameworks, and tooling infrastructure requirements for organizations building or scaling AI teams alongside the governance program defined in this handbook.

Author

Harold W. Webb, PhD, MBA, is Associate Professor Emeritus of Information and Technology Management at The University of Tampa's John H. Sykes College of Business. As department chair, he led the program through ABET accreditation and integrated enterprise systems across the business curriculum. His research focus is technology adoption in organizations and academia. Dr. Webb has taught a variety of undergraduate and graduate courses across the information systems curriculum. Dr. Webb co-authored U.S. Army Research Institute Technical Report 1091 (1999), a synthesis of over 700 management science articles on technology adoption in organizations — research conducted at Texas Tech University that provides the

theoretical foundation for this series. He served as an Army officer for eighteen years, holding command and staff assignments from platoon to corps level, including research and development work on advanced digital systems. He holds a doctorate and MBA from Texas Tech University and a bachelor's degree in accounting from The University of Alabama.

Executive Introduction

Purpose and Scope

Artificial intelligence is no longer a technology project. It is an organizational risk — and increasingly a regulatory obligation. As AI systems touch hiring decisions, credit assessments, customer communications, supply chain operations, and clinical workflows, three questions have moved from the CTO's office to the boardroom: who is responsible, how risks are identified and managed, and how the organization demonstrates accountability to regulators and boards.

This handbook provides managers and senior leaders with a structured, practical framework for enterprise AI governance. It draws on the four authoritative international sources that define the current state of AI governance best practice:

- NIST Artificial Intelligence Risk Management Framework (AI RMF 1.0), January 2023, with the Generative AI Profile (NIST AI 600-1, July 2024) — the leading voluntary framework for AI risk management and governance in the United States (National Institute of Standards and Technology, 2023)
- EU Artificial Intelligence Act (Regulation 2024/1689), entered into force August 2024 — the world's first comprehensive AI legal framework, imposing mandatory governance obligations on organizations providing or deploying AI systems in European markets (European Parliament and Council, 2024)
- ISO/IEC 42001:2023 — the world's first international AI management system standard, published December 2023, providing a certification-grade framework for AI governance aligned with ISO 9001 and ISO 27001 structures (ISO, 2023)
- OECD AI Principles (2019, updated 2024) — the foundational international policy framework endorsed by 46 nations, establishing transparency, accountability, robustness, safety, and fairness as the five pillars of responsible AI (OECD, 2024)

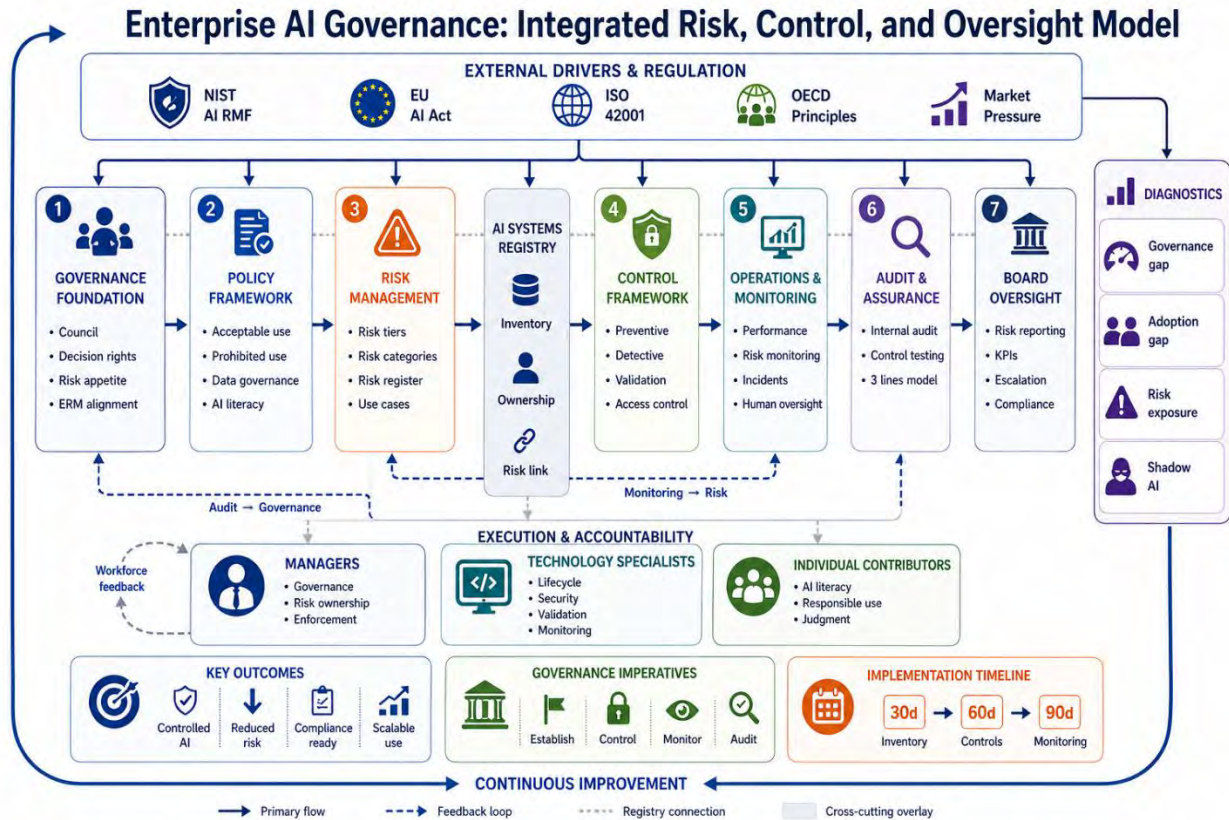


Figure 2-1. Enterprise AI Governance: Integrated Risk, Control, and Oversight Model.

Figure 2-1 presents the integrated governance model that structures this handbook. The seven-stage progression — from Governance Foundation through Board Oversight — maps to the handbook's nine sections. External regulatory drivers (NIST AI RMF, EU AI Act, ISO 42001, OECD Principles) flow into the governance framework from above. Execution and accountability roles (Managers, Technology Specialists, Individual Contributors) connect from below. The diagnostics panel on the right identifies the four organizational gaps this handbook is designed to close: governance gap, adoption gap, risk exposure, and shadow AI.

Each section provides the policy framework, operational guidance, business context, and manager-level action requirements. Every section contains a Why It Matters block written for managers, explaining the business consequences of getting it right — or wrong.

Who This Handbook Is For This handbook is written for: General Managers and Business Unit Leaders responsible for AI-assisted workflows and decisions; Chief Risk Officers and Chief Compliance Officers designing enterprise AI governance programs; Legal and Regulatory Counsel advising on AI-related liability and regulatory exposure; IT and Data Leaders managing AI systems and infrastructure; Board Members overseeing AI strategy and risk at the enterprise level.

Scope and Disclaimer This handbook synthesizes NIST AI RMF 1.0, EU AI Act (2024/1689), ISO/IEC 42001:2023, and OECD AI Principles. It does not replace jurisdiction-specific legal or regulatory obligations. Organizations must obtain qualified legal counsel for their specific jurisdictions, sectors, and AI use cases before relying on this handbook for compliance purposes.

Statement Classification Used in This Handbook

MANDATED — Required by binding law or regulation (e.g., EU AI Act, GDPR). Non-compliance creates direct legal liability.

RECOMMENDED — Prescribed by authoritative voluntary frameworks (NIST AI RMF, ISO/IEC 42001, OECD). Not legally required but reflects accepted best practice; may be assessed in audit or procurement. **E**

MERGING PRACTICE — Observed in leading enterprises; not yet universally adopted or standardized. Adoption varies by organization, sector, and jurisdiction.

⚠ Regulatory Reality Check As of March 2026, over 60 countries have enacted or are actively developing AI regulations (OECD, 2024). Fines under the EU AI Act reach €35 million or 7% of global annual turnover for prohibited AI practices. The NIST AI RMF has been incorporated by reference into U.S. federal agency AI guidance. ISO/IEC 42001 certification is increasingly referenced in enterprise procurement and supply chain contracts, particularly in regulated sectors and among large technology buyers; adoption as a mandatory requirement remains an emerging practice rather than a universal standard. AI governance is no longer optional.

Key Definitions

The following definitions are used consistently throughout this handbook and align with the primary regulatory and standards frameworks cited herein. Where frameworks differ in terminology, the definition reflects the most widely adopted usage.

AI System A machine-based system that, for a given set of human-defined objectives, makes predictions, recommendations, decisions, or generates content that influences real or virtual environments. An AI system can operate with varying levels of autonomy. (Source: EU AI Act Article 3(1); OECD AI Principles, 2024.)

High-Risk AI System An AI system that poses significant risks to the health, safety, or fundamental rights of persons, as defined in Annex III of the EU AI Act (2024/1689). High-risk AI systems are subject to mandatory obligations including risk management systems, data governance, technical documentation, human oversight, and registration. Organizations should note that enterprise-internal risk classification may designate additional systems as high-risk beyond the regulatory definition. (Source: EU AI Act Articles 6 and Annex III.)

General-Purpose AI (GPAI) Model An AI model trained on large volumes of data that is capable of performing a wide range of distinct tasks, and which can be integrated into various AI systems or applications. Large language models (LLMs) are the primary example. Under the EU AI Act, GPAI models are subject to specific obligations from August 2025, including technical documentation, transparency, and compliance with copyright law. GPAI models with systemic risk face additional requirements. (Source: EU AI Act Articles 3(63), 51-55.)

AI Provider vs. AI Deployer The EU AI Act distinguishes between Providers (entities that develop or place an AI system on the market or put it into service) and Deployers (entities that

use an AI system under their authority). Most enterprises are primarily Deployers rather than Providers, but may be classified as Providers if they significantly modify a third-party AI system. Provider and Deployer obligations under the EU AI Act differ materially; this distinction must be determined for each AI system. (Source: EU AI Act Articles 3(3), 3(4), and 25.)

AI Model vs. AI Use Case An AI Model is the underlying trained system (e.g., a large language model, a credit scoring algorithm). A Use Case is the specific deployment context and purpose for which the model is applied (e.g., candidate resume screening, customer support chatbot). Risk classification applies at the use-case level, not the model level: the same model may be low-risk when used for internal process optimization and high-risk when used for employment decisions. Risk assessment and governance obligations must be evaluated for each distinct use case, not once per model.

Agentic AI System An AI system capable of autonomously executing multi-step tasks, using tools, accessing external data sources, and taking actions in digital or physical environments with minimal human intermediation at each step. Agentic systems require enhanced governance controls for action authorization, scope limitation, and audit logging due to their capacity to create irreversible outcomes. (Source: NIST AI 600-1, 2024; not yet specifically defined in EU AI Act.)

Contents

Copyright and Edition Information	2
Rights and permissions	2
Legal disclaimer	2
Case study disclaimer	2
Trademarks	2
Contact.....	2
About This Handbook.....	3
About This Volume	3
The statement classification system	3
Author and AI-tooling acknowledgment	3
Examples and Case Illustrations.....	4
Companion volumes.....	4
Author.....	4
Executive Introduction.....	5
Purpose and Scope	5
Key Definitions	7
Contents	9
Executive Quick Start Reference	13
For board members, C-suite executives, and managers who need to act immediately.	13
EU Enforcement Timeline	14
Phased enforcement of Regulation (EU) 2024/1689 — key dates for enterprise compliance planning.....	14
1. Governance Foundation - Establishing the Structure for Enterprise AI Oversight.....	15
1.1 The AI Governance Council.....	15
Recommended Council Composition.....	16
RACI: AI Governance Council Key Activities	18
1.2 Decision Rights and Escalation Architecture.....	19
AI Decision Rights Framework	19
1.3 Strategic Integration: AI Governance Within Enterprise Risk Management.....	20
2. Policy Framework – Acceptable Use, Prohibition, and Compliance Requirements	22
Framework Traceability Matrix	22
2.1 Core AI Policy Requirements.....	23
AI Literacy Training Requirements by Role (MANDATED: EU AI Act Article 4)	23
2.2 AI Use Approval Process.....	25
AI Use Approval Process Flow	26

2.3 Data Governance Requirements for AI	27
3. Risk Management - Classification, Assessment, and Mitigation of AI Risk	28
3.1 AI Risk Classification Model.....	28
3.2 Core AI Risk Categories	29
3.3 AI Risk Register and Treatment.....	31
3.4 Modern AI Architecture Governance.....	32
4. Control Framework.....	34
4.1 Control Categories.....	34
4.2 AI System Validation and Testing Controls	34
4.3 Access Controls and Data Protection	36
4.4 Audit Trails and Documentation Requirements	37
5. Operations and Monitoring -Continuous Oversight of AI System Performance and Risk	39
5.1 AI Monitoring Program Design.....	39
5.2 Human Oversight Requirements.....	40
5.3 AI Incident Management.....	42
6. Prompt Governance - Controlling Generative AI Interaction as an Enterprise Control Layer	44
6.1 Prompt Classification and Approval	44
6.2 Sensitive Data Controls in Prompts	45
6.3 Prompt Version Control and Change Management.....	46
7. Audit and Assurance - Internal Audit of AI Governance Effectiveness.....	48
7.1 AI Audit Scope and Mandate	48
7.1a Three Lines of Defense: AI Governance Roles	49
7.2 AI Audit Program	51
7.3 Reporting AI Audit Findings	52
8. Board Reporting - Executive and Board-Level AI Governance Reporting	54
8.1 Quarterly AI Risk Report.....	54
Board AI Risk KPI Definitions	55
8.2 Escalation Triggers for Out-of-Cycle Board Reporting	57
9. Continuous Improvement - Maturing the Enterprise AI Governance Program	59
9.1 AI Governance Maturity Model	59
Measurable Maturity Evidence Criteria	61
9.2 Governance Improvement Cycle	63
9.3 Key Governance Improvement Triggers	64
APPENDICES.....	65
SECTION A — AI Systems Registry Template - Authoritative Inventory of Enterprise AI Systems	65

SECTION B — AI Risk Classification Quick Reference - Aligning Internal Classification with EU AI Act Risk Tiers	67
Step 1: Check for Tier 0 — Prohibited Uses	67
Step 2: Check for Tier 1 — High Risk (EU AI Act Annex III)	67
Step 3: Check for Tier 2 — Limited Risk (Transparency Obligations)	68
Step 4: Low Risk Systems	68
SECTION C — AI Incident Response Checklist - Operational Guide for AI Incident Management	69
Phase 1: Detection and Initial Assessment (0-1 Hour)	69
Phase 2: Containment (1-4 Hours)	69
Phase 3: Investigation (4-48 Hours)	70
Phase 4: Remediation (Days 2-30)	70
Phase 5: Post-Incident Review (30-60 Days)	70
SECTION D — Vendor AI Risk Assessment Questionnaire - Third-Party AI Governance Due Diligence	72
Section D.1: AI Governance Program	72
Section D.2: AI Model Documentation and Validation	72
Section D.3: Data Governance and Privacy	73
Section D.4: Security and Access Controls	73
Section D.5: EU AI Act and Regulatory Compliance	73
Section D.6: AI Vendor Contract Clause Checklist	74
SECTION E — Quarterly AI Risk Dashboard - Board-Level Reporting Template	76
E.1 AI Portfolio Summary	76
E.2 Incident Summary	76
E.3 Governance Program Health	77
E.4 Regulatory Status	77
E.5 Emerging Risks and Trends	78
SECTION F — AI Governance Regulatory Reference - Key Standards and Regulatory Frameworks	79
F.1 NIST AI Risk Management Framework (AI RMF 1.0)	79
F.2 EU Artificial Intelligence Act	79
F.3 ISO/IEC 42001:2023 — AI Management System Standard	80
F.4 OECD AI Principles	81
F.5 Key Sector-Specific Frameworks	82
SECTION G — Phased Implementation Roadmap - Building an Enterprise AI Governance Program from Foundation to Maturity	83
Phase 1: Foundation (Days 1–30) — Target: Maturity Level 1 → Level 2 Entry	83
Phase 2: Baseline Governance (Days 31–90) — Target: Maturity Level 2	84

Phase 3: Defined Program (Days 91–180) — Target: Maturity Level 3 Entry84

Phase 4: Managed Program (Days 181–365) — Target: Maturity Level 3.....85

REFERENCES86

Primary Regulatory and Standards Sources86

Government and Regulatory Guidance.....86

Technology Company Documents (Cited as Industry Examples).....87

Academic and Practitioner Research.....87

Legal Records Cited88

News and Trade Press Sources88

GLOSSARY OF TERMS89

Document Revision History92

About the Series93

Executive Quick Start Reference

For board members, C-suite executives, and managers who need to act immediately.

This one-page reference distills the handbook's core requirements into immediate action items. It is not a substitute for the full governance program. It is a starting point for organizations that need to demonstrate governance progress within 30 days.

Priority	Action	Owner	Timeline	Handbook Reference
1	Inventory all AI systems in use across the enterprise — including shadow AI (tools employees use without formal approval). This is the foundation for every other governance action.	CIO / CAIO	Days 1–14	Section A (Registry Template)
2	Classify each AI system by EU AI Act risk tier — Prohibited (Tier 0), High Risk (Tier 1), Limited Risk (Tier 2), Low Risk (Tier 3). Start with the quick reference in Section B.	CRO / Legal	Days 7–21	Section 3.1; Section B
3	Establish or designate an AI Governance Council — a cross-functional body with authority to approve, suspend, or modify AI deployments.	CEO / COO	Days 1–30	Section 1.1
4	Publish an AI Acceptable Use Policy — defining what AI tools are permitted, what data may be shared with AI systems, and what uses are prohibited.	CCO / Legal	Days 14–30	Section 2.1
5	Confirm EU AI Act AI literacy obligation status — Article 4 has been in force since February 2, 2025. If your staff interact with AI in EU-market operations, document what training has been provided.	HR / Legal	Days 1–14	Section 2.1 (Training Matrix)
6	Review AI vendor contracts for data usage, training, and audit clauses. Identify gaps against the contract checklist in Section D.6.	Legal / Procurement	Days 14–30	Section D.6
7	Designate an AI incident responder and distribute the incident response checklist to all AI system owners.	CISO / CRO	Days 1–14	Section C

After the first 30 days, proceed to the phased implementation roadmap in Section G for the 90-day, 180-day, and 365-day governance milestones.

EU Enforcement Timeline

Phased enforcement of Regulation (EU) 2024/1689 — key dates for enterprise compliance planning.

Date	Milestone	What Takes Effect	Who Is Affected
August 1, 2024	AI Act enters into force	20-day publication-to-force period completed	All organizations operating in EU markets
February 2, 2025	Prohibitions + AI Literacy	Article 5 prohibited AI practices banned; Article 4 AI literacy obligation applies	All providers and deployers of AI systems in EU markets
August 2, 2025	GPAI Model Rules	General-Purpose AI model obligations apply (Title V): technical documentation, transparency, copyright compliance; systemic risk models face additional requirements	GPAI model providers (OpenAI, Google, Meta, Anthropic, Mistral, etc.)
August 2, 2026	High-Risk AI + Enforcement	Full high-risk AI obligations apply (Annex III categories): risk management systems, data governance, technical documentation, human oversight, accuracy/robustness, registration; National market surveillance authorities begin enforcement of all provisions including Article 4 AI literacy	Providers and deployers of high-risk AI systems; all organizations for AI literacy enforcement
August 2, 2027	Embedded AI in Regulated Products	High-risk AI systems embedded in products already regulated under EU product safety legislation (medical devices, machinery, vehicles, aviation, etc.) must comply	Manufacturers of regulated products with embedded AI

⚠ Key Planning Note: The August 2026 high-risk compliance deadline is the primary action driver for most enterprises. Organizations deploying AI in Annex III categories (employment, credit, insurance, education, critical infrastructure, biometrics) should have governance programs substantially in place by Q1 2026 to allow testing and remediation time before enforcement begins.

1. Governance Foundation - Establishing the Structure for Enterprise AI Oversight

The governance foundation is the structural backbone of an enterprise AI program. Without it, AI risk management defaults to ad-hoc decisions by individual technical teams, creating accountability gaps, regulatory exposure, and inconsistent risk outcomes. The NIST AI RMF identifies governance as the precondition for all other AI risk management activity: 'Governance provides the structure from which organizations can approach AI risk as a culture and practice, rather than a compliance checklist' (NIST, 2023, AI RMF 1.0, GOVERN function).

ISO/IEC 42001:2023 requires that organizations establish context, define scope, assign accountability, and create documented management system processes before any AI system is deployed. The EU AI Act (Article 9) requires a documented risk management system for all high-risk AI systems, which presupposes an organizational governance structure capable of executing it.

Regulatory Scope Clarification:

Provider vs. Deployer The EU AI Act (2024/1689) assigns materially different obligations depending on whether an organization is a Provider or a Deployer of an AI system. This distinction must be determined for every AI system before governance obligations can be correctly applied.

Misidentifying provider vs. deployer status is one of the most common EU AI Act compliance errors.

Provider (EU AI Act Article 3(3)): An entity that develops an AI system or has an AI system developed, and places it on the market or puts it into service under its own name or trademark, whether for payment or free of charge. An enterprise that builds AI applications for internal deployment may be a Provider. An enterprise that significantly modifies a third-party AI system — changing its intended purpose, substantially altering its performance characteristics, or making it available to others — is treated as a Provider for the modified system (EU AI Act Article 25).

Deployer (EU AI Act Article 3(4)): A natural or legal person that uses an AI system under its own authority, except where the system is used in a personal non-professional activity. Most enterprises procuring and using third-party AI systems (SaaS AI tools, API-accessed AI models, embedded AI in software) are Deployers. Deployers have distinct obligations including human oversight, fundamental rights impact assessment for certain systems, and monitoring — but do not carry the technical documentation and conformity assessment obligations of Providers.

Practical implication for this handbook: Where this handbook references EU AI Act obligations for “organizations,” the specific obligations that apply depend on whether the organization is acting as Provider or Deployer for that system. The governance structures, risk assessment processes, and control frameworks in this handbook are designed to meet both sets of obligations, but the required documentation, conformity assessment, and registration steps differ. Legal counsel must confirm the Provider/Deployer classification for each AI system before compliance activities are planned. This is not a general guidance determination; it is a legal question specific to each system and deployment context.

1.1 The AI Governance Council

An AI Governance Council is the senior cross-functional body responsible for strategic oversight, policy approval, and escalated risk adjudication for all AI systems within the enterprise. It is distinct from day-to-day AI operations management; its mandate is governance — setting rules, approving exceptions, resolving escalations, and providing accountability to the board.

Gartner's 2024 research indicates that organizations with formal AI governance structures are significantly more likely to successfully scale AI from pilot to enterprise-wide deployment (Gartner, 2024). [Note: Gartner figure cited as directional indicator; readers should verify current Gartner research for precise metrics applicable to their sector.]

The structure of the council must reflect the cross-functional nature of AI risk: no single function — not IT, not legal, not risk — has visibility across all dimensions of AI impact.

Recommended Council Composition

Role	Governance Responsibility	Meeting Contribution
Executive Sponsor (CEO/COO)	Strategic direction; enterprise risk tolerance; board liaison	Final escalation authority; resource allocation decisions
Chief AI Officer (CAIO) / CIO	AI strategy, portfolio, and lifecycle management	AI program status; emerging capability and risk signals
Chief Risk Officer (CRO)	Risk appetite alignment; enterprise risk integration	Risk classification decisions; tolerance threshold management
Chief Information Security Officer (CISO)	AI security controls; data protection; threat modeling	Security risk assessment; incident escalation
Chief Compliance Officer (CCO) / General Counsel	Regulatory compliance; legal liability; policy authority	Regulatory updates; legal risk assessment; policy approval
Chief Data Officer (CDO)	Data governance; training data quality; data access controls	Data quality attestation; data governance decisions
Business Unit Representatives (rotating)	Operational context; deployment accountability	Use-case approval requests; operational risk reporting
Chief Audit Executive (CAE)	Independent assurance; audit findings	Audit results; remediation status updates

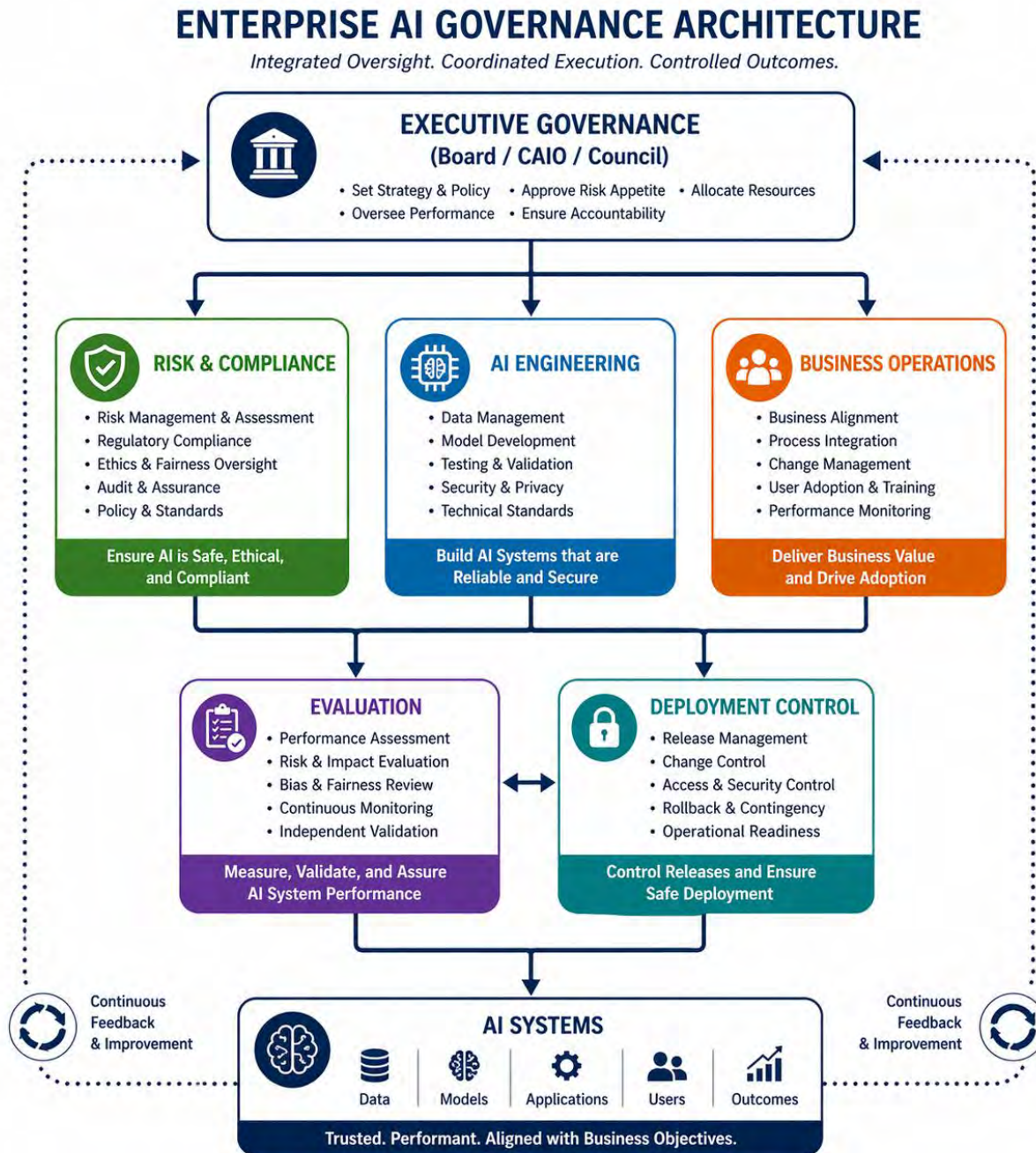


Figure 2-2. **Enterprise AI Governance Architecture**

Figure 2-2 shows the organizational architecture for enterprise AI governance, from Executive Governance (Board, CAIO, Council) through three functional pillars — Risk & Compliance, AI Engineering, and Business Operations — down to Evaluation and Deployment Control functions. The architecture illustrates how strategic oversight, technical execution, and business integration connect through continuous feedback loops to produce trusted, performant AI systems aligned with business objectives.

RACI: AI Governance Council Key Activities

R = Responsible | A = Accountable | C = Consulted | I = Informed | — = Not involved

Activity	Board	CEO/Exec	CAIO/CIO	Risk/CRO	Legal	BU Lead	Audit
AI risk tolerance / appetite setting	A	R	C	C	C	I	I
AI policy approval	I	A	R	C	C	C	I
High-risk AI deployment approval	I	I	R	A	C	C	C
AI risk classification	I	I	R	A	C	R	I
AI incident escalation (Critical)	A	R	R	R	C	I	C
AI regulatory compliance sign-off	I	I	C	C	A/R	I	I
AI audit findings review	A	I	C	C	C	I	R
Board AI risk reporting	A	I	R	C	C	I	C
AI vendor governance oversight	I	I	R	A	C	C	C
AI literacy training (mandate)	I	A	R	I	C	R	I

Foundry's 2025 State of the CIO survey found that 14 percent of surveyed organizations employ a dedicated Chief AI Officer, with 40 percent of those reporting directly to the CEO (CIO Magazine, 2025). This pattern is observed primarily in large enterprises and technology-intensive sectors; CAIO adoption varies significantly by organization size, sector, and geography. In organizations without a CAIO (the majority of enterprises), the CIO typically carries this governance role. This creates structural risk when AI decisions need to take priority over other technology investments.

► **BUSINESS EXAMPLE: JPMorgan Chase AI Governance Structure** JPMorgan Chase established a formal AI governance council structure in 2023, reporting to its Firmwide Risk Committee and Board. The council operates with representation from Technology, Risk, Legal, Compliance, and business lines, and is responsible for reviewing all AI models above a defined risk threshold before production deployment. The bank's 2024 Annual Report disclosed that it has deployed over 400 AI use cases in production and maintains a technology workforce exceeding 60,000 employees, with substantial and growing AI and machine learning specialization across the organization — with each high-risk model subject to governance council review. This structure is directly aligned with the NIST AI RMF GOVERN function requirement for senior-level accountability (JPMorgan Chase, 2024 Annual Report). *Source: JPMorgan Chase & Co., 2024 Annual Report to Shareholders; NIST AI RMF 1.0, GOVERN function (2023).*

WHY IT MATTERS

Without a formal governance council, AI risk decisions are made at the level of individual projects or teams — with no enterprise-wide visibility, no consistent risk thresholds, and no accountability path to the board. When something goes wrong with an AI system — a biased hiring decision, a hallucinated customer commitment, a data breach through an AI interface — the question regulators and litigants ask first is: 'Who was responsible?' A governance council answers that question before the incident, not after. For managers, this means your AI initiatives need a named governance owner, a documented approval process, and a traceable escalation path. Without these, you and your organization carry the liability personally.

1.2 Decision Rights and Escalation Architecture

Decision rights define who has authority to approve, modify, pause, or terminate an AI system at each stage of its lifecycle. Without clearly documented decision rights, organizations experience both bottlenecks (every AI decision escalates unnecessarily) and gaps (high-risk AI decisions are made without appropriate authority).

AI Decision Rights Framework

Decision Type	Required Authority	Escalation Path	Documentation Required
Low-risk AI procurement or deployment	Business unit manager + IT security review	Governance council notification (quarterly summary)	AI Registry entry; security attestation
Medium-risk AI deployment (new model, new data)	Governance council review and approval	CRO sign-off for any deployment above medium threshold	Risk assessment; use case brief; data governance attestation
High-risk AI deployment (EU AI Act Annex III categories or equivalent internal classification)	Full governance council approval; legal review; independent technical validation	CEO/Board notification; regulatory filing where applicable	Complete risk management documentation per Article 9 EU AI Act; NIST MAP/MEASURE attestation
Emergency AI suspension	CISO or CRO acting alone; governance council ratified within 24 hours	Board notification if public-facing or regulatory impact	Incident record; root cause analysis; remediation plan
AI policy exception	Governance council majority; documented exception rationale	Compliance officer attestation; legal review where required	Signed exception form; time-limited authorization; risk acceptance

The NIST AI RMF GOVERN function requires that organizations 'establish and maintain a framework for AI decision rights, accountability, and escalation that is commensurate with the risk of the AI system' (NIST, 2023, GOVERN 1.3). ISO/IEC 42001:2023 Clause 5.3 requires documented roles, responsibilities, and authorities for all AI management system functions.

► **BUSINESS EXAMPLE: NHS England: AI Clinical Escalation Protocol** NHS England's AI Governance Framework (2023) established a three-tier escalation architecture for clinical AI systems: local clinical leads approve routine AI-assisted diagnostic support; regional governance committees review AI systems affecting clinical pathways; the national AI Centre reviews any AI system deployed across multiple trusts or touching core diagnostic or treatment decisions. This structure prevents both under-governance (low-risk tools deployed without oversight) and over-governance (all AI decisions bottlenecked at the national level). The framework explicitly defines that any AI system influencing a clinical decision that affects patient safety is automatically escalated to the regional tier regardless of the AI's risk classification at procurement (NHS England, 2023). *Source: NHS England, AI Governance Framework, 2023; NHS AI Lab, Clinical AI Assurance Guidelines.*

WHY IT MATTERS

For managers, decision rights documentation answers a question you will eventually face in an audit or a board review: 'Who authorized this AI system?' If you cannot answer that question with a document and a signature, your organization has a governance gap. Decision rights also protect managers from informal pressure to deploy AI tools without proper review — having a documented process is the manager's defense against 'just use it and we'll sort out the paperwork later' culture. Define the rights before you need them.

1.3 Strategic Integration: AI Governance Within Enterprise Risk Management

The NIST AI RMF explicitly states that 'AI risk management should be integrated and incorporated into broader enterprise risk management strategies and processes' (NIST, 2023, p. 7). Treating AI risk as a separate silo (managed by IT or data science in isolation from enterprise risk frameworks) is a documented source of governance failure.

The COSO Enterprise Risk Management Framework (2017), which governs risk management practice in most large enterprises, identifies five components relevant to AI governance: Governance and Culture; Strategy and Objective Setting; Performance; Review and Revision; and Information, Communication, and Reporting. Each component has direct implications for AI governance design.

COSO ERM Component	AI Governance Integration Point
Governance and Culture	AI Governance Council mandate; AI code of conduct; leadership tone-setting on responsible AI
Strategy and Objective Setting	AI risk appetite defined in terms of use case categories; alignment with enterprise strategic plan
Performance	AI risk register maintained; AI KRIs monitored; risk thresholds defined and enforced
Review and Revision	Quarterly governance council review; annual policy refresh; trigger-based review on regulatory change

COSO ERM Component	AI Governance Integration Point
Information, Communication, and Reporting	Board AI risk dashboard; regulatory reporting; incident disclosure; third-party AI risk reporting

WHY IT MATTERS

Managers who operate in regulated industries — financial services, healthcare, insurance, energy — are already subject to enterprise risk management requirements under regulatory frameworks (OCC Bulletin 2011-12 for bank model risk, FDA guidance for software as a medical device, FERC cybersecurity standards). AI risk management is not a new obligation; it is an extension of obligations you already carry. The question for managers is whether your current ERM processes have been explicitly extended to cover AI systems, and whether the governance structure that covers your other operational risks also covers AI. If not, you have an accountability gap that regulators and auditors will find.

► BUSINESS EXAMPLE: Goldman Sachs Model Risk Management Framework Extended to AI

Goldman Sachs's 2023 SEC disclosures noted that the firm had explicitly extended its Model Risk Management Policy — previously designed for quantitative financial models — to include AI and machine learning models. The extension required that all AI models used in trading, credit, or client-facing decisions undergo the same validation, documentation, and ongoing monitoring requirements as quantitative financial models. This integration into the existing MRM framework, rather than creating a parallel AI-specific process, allowed the firm to leverage existing governance infrastructure while adding AI-specific controls for explainability and bias. The approach directly aligns with NIST AI RMF guidance to integrate AI risk into existing ERM structures (Goldman Sachs, 2023 Annual Report; SEC 10-K). *Source: Goldman Sachs Group, 2023 Annual Report; NIST AI RMF 1.0, Section 2.2 (2023).*

2. Policy Framework – Acceptable Use, Prohibition, and Compliance Requirements

An AI Policy Framework is the set of formal written policies that govern how AI is used, developed, procured, and retired within the enterprise. Policy provides the normative boundary: it defines what is permitted, what is prohibited, what requires approval, and what conditions must be met before any AI use is approved.

ISO/IEC 42001:2023 Clause 5.2 requires that top management establish, implement, and maintain an AI policy that: is appropriate to the organization's purpose; provides a framework for setting AI objectives; includes a commitment to satisfy applicable requirements; and includes a commitment to continual improvement. The NIST AI RMF GOVERN function requires documented policies that articulate the organization's AI risk tolerance, acceptable use, and accountability structures (NIST, 2023, GOVERN 1.1-1.4).

Framework Traceability Matrix

Each major handbook section maps to specific requirements in the four governing frameworks. This matrix enables compliance officers and auditors to trace handbook guidance to its authoritative sources.

Handbook Section	NIST AI RMF	ISO/IEC 42001:2023	EU AI Act	OECD AI Principles
S1: Governance Structure	GOVERN 1.1–1.7	Clauses 4, 5.1–5.3	Arts. 4, 9, 26–27	Principle 5 (Accountability)
S2: Policy Framework	GOVERN 1.1, 1.4, 6.1	Clause 5.2, Annex A.2	Arts. 4, 5, 9–10	Principles 1–5
S3: Risk Classification	MAP 1.1, 1.5, 2.1–2.3	Clause 6.1, Annex A.5	Arts. 5–9, Annex III	Principle 4 (Robustness)
S4: Control Framework	MANAGE 1.1–2.4	Clauses 8.1–8.5, Annex A	Arts. 9, 10, 12, 15	Principles 3, 4
S5: Monitoring	MANAGE 4.1–4.2	Clause 9.1, Annex A.9	Arts. 9(1)(f), 72–73	Principles 4, 5
S6: Prompt Governance	NIST AI 600-1 (GenAI)	Annex A.6.2	Art. 9 (risk mgmt)	Principle 4
S7: Audit & Assurance	MAP/MEASURE/MANAGE	Clause 9.2–9.3	Art. 9, 17, 62–64	Principle 5
S8: Board Reporting	GOVERN 1.3, 6.2	Clause 9.3	Arts. 9, 26–27	Principle 5
S9: Continuous Improvement	GOVERN 1.7, MANAGE	Clause 10	Art. 9(1)(f)	Principle 5

2.1 Core AI Policy Requirements

Every enterprise AI policy must address five foundational domains. These domains reflect the intersection of NIST AI RMF, EU AI Act, ISO/IEC 42001, and OECD AI Principles requirements:

Policy Domain	Required Content
Acceptable Use	Permitted categories of AI use, by function and risk level; approved AI systems registry; conditions for AI use in public-facing, customer-affecting, or regulated contexts
Prohibited Activities	Explicit list of prohibited AI applications, at minimum aligned with EU AI Act Article 5 prohibitions (social scoring, subliminal manipulation, real-time biometric surveillance in public spaces except narrow law enforcement exceptions, exploitation of vulnerabilities based on age/disability)
Data Governance	Permitted data types for AI training and inference; data quality requirements; prohibited data uses (sensitive personal data, protected class attributes in prohibited contexts); data retention and deletion rules for AI-processed data
Privacy and Security	AI system security requirements; data protection impact assessment requirements for AI processing of personal data; encryption, access control, and audit logging requirements for AI systems
Accountability and Ethics	Transparency requirements (disclosure to affected parties); human oversight requirements for automated decisions; bias monitoring and remediation requirements; whistleblower protections for AI concerns

The EU AI Act Article 4 requires that all organizations provide AI literacy training sufficient for employees to understand and oversee the AI systems they work with. This training obligation applies from February 2025 and is not limited to high-risk AI systems; it applies to any organization whose employees interact with AI. (EU AI Act, Article 4, 2024)

AI Literacy Training Requirements by Role (MANDATED: EU AI Act Article 4)

EU AI Act Article 4 requires organizations to ensure that staff have sufficient AI literacy for their role and the AI systems they interact with. This obligation applies from February 2025 to all organizations whose employees use AI systems in EU-market operations — it is not limited to high-risk AI. The following matrix operationalizes this requirement by role category. Organizations should adapt training depth to the specific AI systems deployed in each function.

Role Category	Training Depth	Required Training Content	Key Competencies	Frequency
End User (any staff using AI tools)	Basic	Acceptable use policy; prohibited AI uses; data classification and prompt hygiene; how to identify AI-generated content; incident reporting procedure; shadow AI risks	Understand what AI can and cannot do reliably; recognize when AI output requires verification; know what data must not be entered into AI systems; understand how to report AI concerns	Annual; on-boarding

Role Category	Training Depth	Required Training Content	Key Competencies	Frequency
Manager / Business Unit Leader	Intermediate	All basic content plus: AI risk classification and governance process; use case approval process; human oversight obligations; bias and fairness concepts; manager accountability under EU AI Act	Identify high-risk AI use cases in their area; fulfill AI approval process requirements; design human oversight mechanisms; recognize governance gaps; understand personal liability exposure	Annual; on role change
AI/Data Developer and Engineer	Advanced	All intermediate content plus: technical AI risk categories (hallucination, bias, data leakage, prompt injection); NIST AI RMF TEVV methodology; data governance for AI; model validation requirements; secure AI development practices	Apply bias testing methodologies; conduct security testing for AI systems; implement audit logging; design explainability outputs; manage model lifecycle governance	Annual; on technology change
Executive / C-Suite	Strategic	AI governance framework overview; regulatory landscape and enforcement risk; board reporting obligations; AI risk appetite-setting; organizational liability for AI outputs; strategic AI governance investment	Set AI risk tolerance; hold governance council accountable; interpret board AI risk reports; understand personal and organizational regulatory exposure; make informed AI investment decisions	Annual
Legal / Compliance / Risk	Specialist	All intermediate content plus: EU AI Act obligations in depth (provider vs. deployer, high-risk categories, prohibitions, penalties); GDPR AI processing requirements; sector-specific AI regulation; regulatory notification requirements; vendor contract AI obligations	Conduct regulatory gap analysis; advise on AI use case compliance; draft AI governance policies; manage regulatory notifications; assess vendor AI contracts; support audit activities	Semi-annual; on regulatory change

Role Category	Training Depth	Required Training Content	Key Competencies	Frequency
Internal Audit	Specialist	All intermediate content plus: AI audit methodology; AI control testing techniques; AI risk register assessment; bias testing audit procedures; AI incident management audit; governance maturity assessment	Design and execute AI governance audits; assess control effectiveness; test bias and fairness claims; evaluate human oversight mechanisms; assess regulatory compliance evidence	Annual; on methodology change

► **BUSINESS EXAMPLE: Microsoft Responsible AI Standard** Microsoft published its Responsible AI Standard (Version 2.0, 2022) as an enterprise-wide policy framework governing all AI development and deployment across its product lines. The Standard defines six core requirements applicable to all AI systems: Fairness, Reliability and Safety, Privacy and Security, Inclusiveness, Transparency, and Accountability. Each requirement is operationalized through specific engineering requirements, validation gates, and documentation standards. The Standard explicitly prohibits: AI systems that use real-time facial recognition to track individuals in public spaces; AI systems that infer protected attributes for decisions affecting individuals without explicit consent; and AI systems that take consequential actions on behalf of users without maintaining an auditable override mechanism. The Standard has been incorporated into Microsoft's vendor contracts, requiring third-party AI providers to meet equivalent standards before Microsoft deploys their models in enterprise products (Microsoft, Responsible AI Standard v2, 2022). *Source: Microsoft Corporation, Responsible AI Standard Version 2.0, June 2022. Available at microsoft.com/en-us/ai/responsible-ai.*

WHY IT MATTERS

A policy without enforcement is not a policy — it is a document that will be used against you in litigation. For managers, the critical question is not whether your organization has an AI policy (most do), but whether that policy is: reviewed and approved by appropriate authority; communicated and understood by all staff who interact with AI; enforced with consequences for violations; and updated when regulatory requirements change. The EU AI Act's AI literacy obligation (Article 4) means that as a manager you are personally responsible for ensuring your team understands the AI systems they use. A documented training program is not optional; it is a legal requirement in EU-market organizations from February 2025.

2.2 AI Use Approval Process

All AI systems used within the enterprise — whether built internally, procured from vendors, accessed through APIs, or used informally by employees on personal or work devices — require formal approval before use in business operations. This requirement is grounded in the ISO/IEC 42001 Clause 8.2 operational planning and control requirements, and in the NIST AI RMF MAP function requirement to catalog all AI use across the organization.

AI Use Approval Process Flow

Stage	Required Actions and Documentation
1. Identification	Business unit submits AI Use Request Form describing: proposed AI system; intended use case; data inputs; affected parties; business justification
2. Risk Classification	AI Governance function applies risk classification (see Section 3.1) to determine review tier; outcome documented in AI Registry
3. Policy Review	Compliance officer reviews against Acceptable Use and Prohibited Activities policy; flags if use case falls in prohibited or restricted categories
4. Technical Review	IT Security reviews access controls, data handling, API security, vendor security attestations; Data office reviews data governance alignment
5. Approval Decision	Low-risk: IT Security and Compliance sign-off sufficient. Medium-risk: AI Governance Council review. High-risk: Full council approval + legal sign-off + independent validation
6. Registry Entry	Approved AI system entered in AI Systems Registry with risk classification, approval date, approving authority, review schedule, named owner
7. Ongoing Review	Annual re-review for low-risk; semi-annual for medium-risk; quarterly for high-risk; trigger-based review on any significant change to the AI system, data inputs, or use context

► **BUSINESS EXAMPLE: Unilever AI Use Policy — Shadow AI Control** Unilever's 2023 AI governance update addressed the growing problem of 'shadow AI', employees using AI tools outside the official approval process. The policy established that any AI tool used in any business process — regardless of whether it was procured by IT or accessed individually by an employee — required registration in the enterprise AI registry. Employees found using unregistered AI tools were subject to disciplinary procedures. The policy was accompanied by a 'fast-track approval' process for commonly requested consumer AI tools (ChatGPT, Copilot, Midjourney) that provided a 48-hour decision turnaround for standard use cases. The shadow AI control was directly motivated by an incident in which a team had used a consumer AI tool to process supplier contract data, inadvertently sharing confidential commercial terms with the AI provider's systems (Unilever, 2023 Annual Report and AI Policy disclosures). *Source: Unilever PLC, 2023 Annual Report; AI Policy Framework disclosures; reported in Harvard Business Review, 2024.*

WHY IT MATTERS

Shadow AI — employees using AI tools that have not been formally approved — is the single greatest source of data leakage risk in most enterprises right now. For managers, this means you need to know what AI tools your team is using, not just what tools you have approved. If your team is using ChatGPT, Copilot, Gemini, or any AI tool to process business data — customer information, contracts, financial data, health information — without formal approval, your organization is almost certainly in breach of data protection obligations. The fast-track approval process Unilever introduced is the model: make the approved path easy enough that employees choose it over the shadow path.

2.3 Data Governance Requirements for AI

AI systems are fundamentally data systems. The quality, representativeness, provenance, and governance of training and inference data is the single greatest determinant of whether an AI system produces reliable, fair, and legally compliant outputs. The EU AI Act Article 10 imposes mandatory data governance requirements on all high-risk AI systems: training, validation, and testing datasets must be relevant, sufficiently representative, free from errors to the best extent possible, and have appropriate statistical properties for the intended purpose (EU AI Act, Article 10, 2024).

Data Governance Requirement	Standard Reference	Enterprise Obligation
Training data documentation	EU AI Act Art. 10; NIST MAP 2.1	Maintain provenance records for all AI training datasets; document source, collection date, selection criteria, and known limitations
Representative sampling validation	EU AI Act Art. 10(3); NIST MEASURE 2.5	Validate that training data is representative of the deployment population; document bias testing results
Personal data minimization	EU GDPR Art. 5(1)(c); EU AI Act Art. 10	Use minimum necessary personal data for AI training; document data minimization decisions; obtain required consents
Data quality monitoring	ISO/IEC 42001 Annex A.8; NIST MAP 5	Monitor inference data quality in production; alert on distribution shift; document data quality incidents
Third-party data contracts	NIST GOVERN 6.1; ISO 42001 Cl. 8.4	Require AI data governance representations from all data suppliers; include audit rights in data contracts

WHY IT MATTERS

For managers, data governance for AI is not a technical problem — it is a business accountability problem. When your AI system produces a biased credit decision, a discriminatory hiring recommendation, or a privacy violation, regulators and courts will ask: What data was used to train this system? How was it validated? Who approved its use? If you cannot answer these questions with documentation, the liability rests with the deploying organization — and with the manager responsible for the deployment. Data governance documentation is your evidence of due diligence.

3. Risk Management - Classification, Assessment, and Mitigation of AI Risk

AI risk management is the process by which an enterprise systematically identifies, assesses, prioritizes, and mitigates the risks posed by AI systems throughout their lifecycle. It is the core operational function that translates governance principles and policy commitments into actual organizational protection.

The NIST AI RMF structures AI risk management across three functions: MAP (contextualizing AI risk), MEASURE (quantifying AI risk), and MANAGE (treating AI risk). The EU AI Act mandates documented risk management systems for all high-risk AI systems under Article 9. ISO/IEC 42001 Clause 6.1 requires organizational AI risk assessment, and Annex A contains controls specifically addressing AI system risk categories (NIST, 2023; EU AI Act, 2024; ISO, 2023).

3.1 AI Risk Classification Model

Before any AI risk can be assessed or mitigated, it must be classified. The classification framework determines the required governance oversight, documentation depth, and control intensity for each AI system. This handbook aligns the classification with the EU AI Act's risk tiers — the only binding international legal framework — while extending it to cover enterprise-internal risk dimensions not addressed by the regulation.

Risk Tier	EU AI Act Designation	Enterprise Characteristics and Examples
Tier 0 — Prohibited	Unacceptable Risk (Article 5)	Banned outright: AI social scoring systems; real-time biometric surveillance in public spaces (except narrow law enforcement); subliminal manipulation of individuals; exploitation of vulnerabilities based on age, disability, or socio-economic status to distort behavior
Tier 1 — High Risk	High Risk (Annex III categories)	Significant impact on safety, fundamental rights, or regulated decisions: AI in hiring and HR (CV screening, performance evaluation); AI in credit scoring and insurance pricing; AI in educational assessment; AI in law enforcement or border control; AI systems used in critical infrastructure management; medical device AI
Tier 2 — Medium Risk	Limited Risk (transparency obligations)	Moderate impact with disclosure requirements: AI-generated content (text, images, audio) in customer-facing applications; chatbots interacting with consumers; emotion recognition AI; automated decision support with human review; AI-assisted risk scoring without direct decision output
Tier 3 — Low Risk	Minimal Risk (no mandatory obligations)	Low impact, no direct effect on individuals: internal process optimization AI; AI for IT operations and code review; content recommendation AI for internal use; manufacturing process optimization AI

The EU AI Act Annex III high-risk categories include: biometric identification and categorization; critical infrastructure management (energy, water, transport, finance); educational and

vocational training; employment and workforce management; access to essential services (credit, insurance, social benefits); law enforcement; migration and asylum; administration of justice. Enterprises deploying AI in any of these categories face the most extensive compliance obligations (EU AI Act, Annex III, 2024).

► **BUSINESS EXAMPLE: Amazon Halts AI Hiring Tool Over Bias** Amazon's internal AI hiring tool, developed from 2014 and abandoned in 2018, was designed to rate job candidates on a 5-star scale using resumes as inputs. The system trained on historical hiring data that predominantly reflected male engineers, causing it to systematically downgrade resumes from women — penalizing resumes that included words like 'women's' (as in 'women's chess club') and downgrading graduates of two all-female colleges. Under the EU AI Act's Annex III framework, this system would be classified as Tier 1 (High Risk) — AI systems used in employment recruitment and selection. The mandatory requirements that would have applied under the EU AI Act: documented risk management system; bias testing against protected class characteristics; human oversight mechanism; technical documentation demonstrating fitness for purpose. Amazon's failure to implement any of these controls is the documented basis for its abandonment. The case is now the canonical example of AI hiring bias in regulatory guidance globally (Reuters, 2018; EU AI Act Explanatory Memorandum, 2024). *Source: Reuters, 'Amazon scraps secret AI recruiting tool that showed bias against women,' October 2018; European Commission, EU AI Act Explanatory Memorandum, 2024.*

WHY IT MATTERS

For managers, risk classification is the critical gateway decision. If you deploy a Tier 1 high-risk AI system without knowing it is high-risk, you are fully exposed to regulatory enforcement — including fines up to 3% of global annual turnover under the EU AI Act — without the benefit of any documented due diligence. The classification exercise takes less than a day for most AI systems and requires checking your intended use case against Annex III of the EU AI Act. For U.S.-only deployments, the equivalent check is against the NIST AI RMF MAP function's recommended impact analysis. The Amazon case shows what happens when this step is skipped.

3.2 Core AI Risk Categories

Beyond regulatory classification, enterprise AI risk management must assess risk categories unique to AI systems that do not appear in traditional IT risk frameworks. The NIST AI RMF identifies the following primary AI risk categories, each of which requires specific mitigation strategies (NIST, 2023):

Risk Category	Definition	Key Indicators	Primary Mitigation
Hallucination and Factual Error	AI generates plausible but incorrect outputs with apparent confidence; system cannot reliably distinguish between reliable and unreliable outputs	Documented instances of factually wrong AI outputs used in decisions; absence of output verification protocols; user over-reliance on AI outputs	Triangulation protocols; human review gates for consequential outputs; explicit model limitations documentation; output confidence scoring where available

Risk Category	Definition	Key Indicators	Primary Mitigation
Bias and Discrimination	AI system produces systematically different outcomes for individuals based on protected characteristics (race, gender, age, disability, national origin) without legitimate basis	Disparate impact analysis showing statistically significant differences in AI output distributions across protected groups	Pre-deployment bias testing; ongoing disparate impact monitoring; diverse training data validation; bias incident response protocol
Data Leakage and Privacy Violation	AI system exposes personal, confidential, or proprietary data outside its intended access boundary; training data memorization; prompt injection attacks revealing system data	Employees using AI tools to process data without DPA-compliant safeguards; AI inference revealing information contained in training data; prompt injection attacks on customer-facing AI	Data classification for AI inputs; DLP controls on AI interfaces; prompt injection testing; privacy impact assessments; vendor data processing agreements
Opacity and Explainability Failure	AI system makes consequential decisions that affect parties or oversight functions cannot understand or challenge; 'black box' problem	Decisions affecting individual rights, access to services, or employment cannot be explained to affected parties; audit trails insufficient to reconstruct AI decision logic	Explainability requirements in AI procurement; SHAP/LIME or equivalent explanation outputs for high-risk decisions; human-interpretable documentation of model logic
Regulatory Non-Compliance	AI deployment violates applicable laws, regulations, or binding guidance, exposing the enterprise to enforcement action, fines, and liability	High-risk AI system deployed without EU AI Act-compliant documentation; AI processing EU personal data without GDPR-compliant basis; AI hiring decisions made without required human review	Regulatory mapping per jurisdiction before deployment; compliance sign-off in deployment approval process; ongoing regulatory monitoring
Vendor and Third-Party AI Risk	Enterprise deploys AI capabilities provided by third parties (APIs, SaaS AI tools, embedded AI in software) without adequate risk assessment of the underlying model	Third-party AI vendor unable to provide documentation of model training, testing, bias evaluation, or security controls; vendor contract lacks audit rights or AI governance representations	Vendor AI security questionnaire; contractual representations and warranties on AI governance; vendor audit rights; assessment of vendor's own AI governance maturity

► **BUSINESS EXAMPLE: Apple's 2023 Restriction on ChatGPT Use by Employees** In May 2023, Apple restricted its employees from using ChatGPT and GitHub Copilot for work tasks, citing concerns about the risk of confidential data leaking to third-party AI systems. The concern was specifically about training data memorization — the risk that information provided to AI systems could be retained and later returned to other users or used to train future model versions. The restriction reflected the Data Leakage risk category: Apple's source code, product roadmaps, and customer data could be inadvertently disclosed to OpenAI's systems through employee use of ChatGPT for code review or document drafting. Apple subsequently developed its own private AI infrastructure (Apple Intelligence, announced 2024) designed to run AI inference on-device or in Apple's Private Cloud Compute, specifically to mitigate the data leakage risk that justified the ChatGPT restriction (Wall Street Journal, 2023; Apple, WWDC 2024). *Source: Wall Street Journal, 'Apple Restricts ChatGPT Use Among Employees Over Confidentiality Concerns,' May 2023; Apple Inc., WWDC 2024 Private Cloud Compute technical documentation.*

WHY IT MATTERS

For managers, risk category awareness is operational self-protection. The six risk categories above are the documented sources of AI governance failures that have produced regulatory enforcement, litigation, and reputational damage in the past five years. Each one has a documented business example. Each one has a tested mitigation strategy. Investing in risk assessment before deployment is consistently cheaper than remediating a violation after deployment. It is dramatically cheaper than defending an enforcement action or class action lawsuit.

3.3 AI Risk Register and Treatment

The AI Risk Register is the enterprise's authoritative inventory of identified AI risks, their assessed severity, assigned owners, treatment plans, and residual risk levels. It is analogous to the enterprise risk register used in COSO ERM, extended with AI-specific risk dimensions.

ISO/IEC 42001 Clause 6.1.2 requires that organizations maintain documented information on the AI risk assessment process, including the results of each assessment. NIST AI RMF MAP 5 requires that organizations document the likelihood and magnitude of potential AI harms. The EU AI Act Article 9(2) requires high-risk AI providers to maintain an ongoing risk management system throughout the system's lifecycle.

Risk Register Field	Required Content
Risk ID	Unique identifier; linked to AI Systems Registry entry
AI System	Name, version, and purpose of the AI system generating the risk
Risk Category	From the taxonomy in Section 3.2 above
Risk Description	Specific statement of the risk: what could go wrong, under what conditions, with what consequences
Likelihood	Assessed probability of occurrence: Rare / Unlikely / Possible / Likely / Almost Certain

Risk Register Field	Required Content
Impact	Assessed severity of consequence: Negligible / Minor / Moderate / Major / Critical; dimensions: financial, regulatory, reputational, operational
Inherent Risk Rating	Likelihood × Impact matrix score; mapped to Low / Medium / High / Critical
Current Controls	Existing mitigations; assessed control effectiveness
Residual Risk	Risk rating after accounting for current controls
Treatment Decision	Accept / Mitigate / Transfer / Avoid; documented rationale
Treatment Owner	Named individual responsible for executing the treatment plan
Target Completion	Date by which treatment will be implemented
Status	Not Started / In Progress / Complete / Overdue
Last Review Date	Date of most recent risk review; next scheduled review date

WHY IT MATTERS

The AI Risk Register is your primary management accountability tool. In a regulatory audit, the first document requested is the AI inventory — every AI system you use, its risk classification, and its documented risk assessment. Organizations that cannot produce this document on request face the presumption that their governance program exists on paper only. More practically: the risk register is how you know whether your AI program is getting safer over time. If residual risk ratings are declining and treatment plans are being completed, governance is working. If they are flat or rising, something needs attention at the governance council level.

3.4 Modern AI Architecture Governance

The risk classification model in Section 3.1 applies to AI use cases at the level of their deployment context. However, the underlying architecture of modern AI systems introduces additional governance considerations that do not appear in traditional software risk frameworks. The following four architecture types require specific governance controls beyond those applicable to conventional AI systems. They must be explicitly assessed during use case approval for any system using these approaches.

Architecture Type	Specific Risk Dimensions	Additional Required Controls	Governance Source
Retrieval-Augmented Generation (RAG)	Output quality and accuracy directly depends on retrieved data sources; data source errors or staleness propagate directly into AI outputs; data source access creates data leakage risk; document provenance may be unclear	Data source inventory and quality assessment; data source access controls and logging; retrieval output validation layer; document provenance tracking; regular data source currency review; testing for retrieval failures and hallucination under stale data conditions	NIST AI 600-1 (2024); OWASP LLM Top 10 2025 (LLM08: Vector and Embedding Weaknesses)
Agentic AI Systems	Autonomous multi-step action execution creates irreversible outcomes without human intermediation; scope creep beyond intended task boundaries; action authorization gaps; cascading failures across integrated systems; audit trail gaps for autonomous actions	Explicit action authorization framework (what actions may the agent take autonomously vs. require human approval?); scope boundary definition and enforcement; action logging with sufficient granularity for audit; reversibility assessment for each permitted action category; emergency halt mechanism; regular scope review	NIST AI 600-1 (2024); EU AI Act Arts. 14 (human oversight); OECD AI Principle 1.4
Multi-Model Orchestration	Risk classification applies at the use-case level but risk behavior emerges from model interactions not present in any single model; output from one model becomes input to another without intervening human review; bias in intermediate models may amplify; responsibility for failures may be unclear across models	End-to-end use case risk classification (not per-model); inter-model output validation gates; complete audit logging across the full model chain; vendor risk assessment for each model in the chain; clear accountability assignment for the full orchestrated system	NIST AI RMF MAP 1.5; ISO/IEC 42001 Clause 6.1
Fine-Tuned and Open-Source Models	Fine-tuning on enterprise data creates training data governance obligation; open-source model provenance may be uncertain; training data memorization in fine-tuned models creates data leakage risk; open-source models may lack vendor support for incident response or security updates	Training data documentation and GDPR legal basis assessment before fine-tuning; bias testing of fine-tuned model against base model; open-source model provenance and license review; security vulnerability scanning; internal model risk classification and documentation equivalent to vendor model requirements; incident response plan without vendor support	EU AI Act Art. 10 (data governance); NIST AI RMF GOVERN 6.1; ISO/IEC 42001 Annex A.8

4. Control Framework

An AI control framework establishes safeguards, mechanisms, and procedures that prevent AI systems from operating outside their defined boundaries, producing unauthorized outputs, accessing unauthorized data, or evading human oversight. Controls are the operational expression of governance intent. They translate policy requirements into concrete, testable, and auditable actions.

The NIST AI RMF MANAGE function requires that organizations 'implement plans to respond to and recover from incidents related to AI systems and develop organizational procedures to document AI risks, implement responses, and communicate to relevant internal and external stakeholders' (NIST, 2023). ISO/IEC 42001 Annex A provides a control catalogue directly analogous to ISO/IEC 27001's information security controls but specifically designed for AI systems.

4.1 Control Categories

AI controls are organized across four categories, each addressing a distinct layer of the AI governance stack:

Control Category	Purpose	Examples
Preventive Controls	Prevent AI system failures, misuse, or unauthorized actions before they occur	Access control policies; data input validation; prohibited use restrictions; AI procurement requirements; training data governance
Detective Controls	Identify AI system anomalies, failures, policy violations, or unauthorized behavior after they occur	Model performance monitoring; bias detection scans; anomaly detection on AI outputs; audit logging; user behavior analytics
Corrective Controls	Restore AI systems to intended operation following detected failure or incident	Incident response procedures; model rollback capability; emergency suspension process; human override mechanisms; bias remediation workflows
Directive Controls	Guide personnel toward compliant and responsible AI use through training, policy, and standards	AI acceptable use policy; AI literacy training; use case approval workflow; prompt governance standards; vendor management requirements

4.2 AI System Validation and Testing Controls

Before any AI system is approved for production deployment, it must undergo a documented validation process that demonstrates fitness for intended purpose and compliance with applicable requirements. The EU AI Act Articles 9 and 15 require that high-risk AI systems be tested against their intended use cases and that testing demonstrates appropriate levels of accuracy, robustness, and resilience. NIST AI RMF MEASURE 2 addresses testing, evaluation, verification, and validation (TEVV) requirements (EU AI Act, 2024; NIST, 2023).

Validation Requirement	Enterprise Implementation Standard
Functional accuracy testing	Test set performance against use case requirements; documented accuracy thresholds by use case; comparison to non-AI baseline performance
Robustness testing	Testing under edge cases, adversarial inputs, and out-of-distribution data; documented performance degradation thresholds; failure mode analysis
Bias and fairness evaluation	Disparate impact testing across protected class characteristics; documented demographic parity and equal opportunity metrics; bias testing against applicable fairness standards (NIST AI RMF MEASURE 2.11)
Security penetration testing	Prompt injection testing; model extraction attempts; data poisoning resilience assessment; adversarial example resistance
Privacy impact assessment	GDPR-compliant DPIA for AI systems processing personal data; documented legal basis for AI data processing; data minimization assessment
Explainability assessment	Documentation of AI decision logic for high-risk decisions; test of explanation quality against affected-party comprehension standards
Human oversight validation	Test that human override mechanisms function as designed; validation that AI decision outputs are presented in a form that enables meaningful human review

► **BUSINESS EXAMPLE: Google DeepMind Safety Evaluation Framework** Google DeepMind published its Frontier Safety Framework in 2024, establishing evaluation protocols for large-scale AI models. The framework requires three categories of pre-deployment evaluation: Capability Evaluations (what the AI can do, including for potentially dangerous purposes); Safety Evaluations (whether safety mitigations remain effective against identified risks); and Societal Risk Evaluations (potential impacts on information environments, critical infrastructure, and democratic processes). DeepMind commits to not deploying models that exceed defined Critical Capability Levels without additional mitigations in place. The framework is notable for establishing 'red lines' — capability thresholds that trigger deployment pause regardless of commercial pressure. This pre-deployment validation approach directly operationalizes the NIST AI RMF MEASURE function and the EU AI Act Article 9 risk management requirements (Google DeepMind, Frontier Safety Framework, 2024). *Source: Google DeepMind, Frontier Safety Framework, May 2024. Available at deepmind.google/safety.*

WHY IT MATTERS

Validation is the governance control that protects managers from deploying AI systems that will fail in production. Every documented AI failure with significant business or regulatory consequences — the Amazon hiring tool, the Air Canada chatbot liability case, the healthcare diagnosis over-reliance cases — involved deployment without adequate pre-deployment validation. The NIST TEVV framework gives you a structured validation checklist. The question for managers is: Has this AI system been formally tested against the conditions it will actually face in production? If the answer is 'we don't know,' the validation has not been done.

4.3 Access Controls and Data Protection

AI systems access, process, and generate data. Access control for AI differs from traditional IT access control in three important ways: (1) the AI system itself is an active data processor, not just a passive repository; (2) AI systems can be prompted to reveal training data through carefully crafted inputs; (3) AI agents may access organizational data autonomously, without human intermediation at each access decision.

Access Control Requirement	Implementation Standard
Data classification enforcement	All data input to AI systems must be classified; AI systems must be configured to reject or flag data above their authorized classification level
Least-privilege data access	AI systems and AI agents granted minimum data access necessary for their intended function; access reviewed quarterly; excess permissions removed
User access controls	Role-based access control for all AI system interfaces; multi-factor authentication for AI systems with access to sensitive data; privileged access management for AI system configuration and training functions
Audit logging	All AI system access, queries, and outputs logged with sufficient granularity to support incident investigation; logs retained per applicable regulatory requirements; logs protected against tampering
Data loss prevention	DLP controls configured to detect and prevent sensitive data exfiltration through AI interfaces; monitoring for unusual data access patterns by AI systems and users
Vendor data protection	Contractual prohibitions on AI vendors using enterprise data for model training without explicit consent; data processing agreements compliant with GDPR and applicable local law; right to request data deletion

► **BUSINESS EXAMPLE: Samsung Data Leak via ChatGPT (2023)** In April 2023, Samsung engineers used ChatGPT to assist with code debugging. In three separate incidents within a single month, employees input sensitive information into ChatGPT: source code for a semiconductor equipment database; source code related to a program for identifying defects in equipment; and notes from a meeting about business strategy. Samsung's existing DLP controls were not configured to detect data uploaded to external AI systems through browser interfaces. The incidents prompted an immediate restriction on AI tool use and triggered an enterprise-wide review of AI data governance controls. Samsung subsequently began developing internal AI infrastructure. The Samsung incidents are now the reference case in enterprise AI data governance guidance globally — cited in NIST AI 600-1, ISO/IEC 42001 implementation guidance, and EU AI Act practitioner materials (Bloomberg, 2023; Samsung internal communications reported in The Verge, 2023). Source: Bloomberg, 'Samsung Bans Employee Use of AI Tools Like ChatGPT After Sensitive Data Leak,' April 2023; The Verge, April 2023.

WHY IT MATTERS

Access control for AI is the most immediately actionable governance control for managers. You do not need a governance council resolution to configure DLP controls for AI interfaces. The Samsung incidents happened because standard DLP tools were not configured to cover browser-based AI tool access — a configuration gap, not a capability gap. For managers, the question is: Do our existing DLP and data classification controls cover the AI tools your team currently uses? If not, this is a same-day remediation priority.

4.4 Audit Trails and Documentation Requirements

Audit trails for AI systems serve three governance purposes: operational monitoring (detecting anomalies and incidents in real time); incident investigation (reconstructing what happened after a failure or complaint); and regulatory compliance (demonstrating to regulators and auditors that required controls were in place and effective).

The EU AI Act Article 12 requires that high-risk AI systems maintain automatic logging capabilities that enable post-market monitoring and investigation of incidents throughout the system's lifetime. NIST AI RMF MANAGE 1.4 requires documentation of AI incident response actions and their outcomes (EU AI Act, Article 12; NIST, 2023).

Audit Trail Element	Required Retention and Content Standard
AI system access logs	Who accessed the AI system, when, and from where; query inputs where required by the risk level; all administrative and configuration actions — minimum 2 years retention
Model decision logs	Inputs to AI decision-making functions; outputs including confidence scores where available; any human override actions — retained for the period during which affected parties may bring claims
Training and configuration logs	Version history of AI model; all training data updates; configuration changes; validation test results for each version — retained throughout system lifetime
Incident logs	Complete record of each AI incident: detection trigger; investigation findings; root cause; remediation actions; affected parties; regulatory notifications — minimum 5 years retention
Third-party AI audit logs	Audit logs from third-party AI providers where contractually obtained; vendor incident reports; vendor compliance certifications — retained per the relevant vendor contract period plus 2 years

WHY IT MATTERS

Audit trails are the difference between being able to defend your governance program and being unable to. In the event of a regulatory investigation, a whistleblower complaint, or customer litigation, the question will be: What did the AI system do, when, and why? Without audit logs, you cannot answer this question. With audit logs that are incomplete, inconsistently maintained, or retroactively modified, you face worse exposure than having no logs. For managers, this means: verify that your AI systems are generating logs, that logs are being stored, and that someone is responsible for their integrity and availability when needed.

5. Operations and Monitoring -Continuous Oversight of AI System Performance and Risk

AI governance does not end at deployment. AI systems change — their performance degrades, their operating environment shifts, their outputs drift from intended behavior, and new vulnerabilities emerge. The NIST AI RMF MANAGE function explicitly addresses post-deployment monitoring as a core governance requirement: 'AI systems are monitored after deployment, and relevant metrics are tracked to assess AI system performance' (NIST, 2023, MANAGE 4.1).

ISO/IEC 42001 Clause 9.1 requires performance evaluation and monitoring as a standing organizational requirement. The EU AI Act Article 9(1)(f) requires an ongoing risk management system that identifies and analyzes known and foreseeable risks throughout the system's lifecycle — not just at initial deployment (EU AI Act, 2024; ISO, 2023).

5.1 AI Monitoring Program Design

An effective AI monitoring program tracks four distinct dimensions of AI system health, each requiring different metrics, different monitoring cadences, and different response protocols:

Monitoring Dimension	What It Tracks	Key Metrics	Response Threshold
Technical Performance	Whether the AI system is producing outputs of the quality and reliability it was validated for at deployment	Accuracy rate; error rate; precision/recall; confidence distribution; latency; uptime	Alert when accuracy drops >5% from baseline; investigate when confidence distribution shifts; escalate when error rate exceeds validated threshold
Risk Compliance	Whether the AI system continues to operate within its defined risk parameters and does not generate prohibited or restricted outputs	Bias metric trends (disparate impact ratios); prohibited output detection; data access pattern anomalies; prompt injection attempt rates	Suspend deployment when disparate impact ratio exceeds defined threshold; escalate all confirmed prompt injection successes; alert on access pattern anomalies
Incident Tracking	Whether AI system incidents are being detected, recorded, and resolved appropriately	Incident count by severity; mean time to detection; mean time to resolution; incident recurrence rate; near-miss reports	Governance council review when monthly incident rate increases >20%; CEO notification for Critical severity incidents; regulatory notification within required timeframes

Monitoring Dimension	What It Tracks	Key Metrics	Response Threshold
Human Oversight Effectiveness	Whether human oversight mechanisms are functioning as designed — i.e., that humans are actually reviewing AI outputs when required, and that overrides are being exercised appropriately	Override rate by decision category; time-to-review for AI recommendations; percentage of AI decisions with documented human review; review quality sampling results	Investigate if override rate drops to near-zero (may indicate rubber-stamping); escalate if review completion rates fall below required threshold; audit review quality if sampling detects systematic approval without genuine review

► **BUSINESS EXAMPLE: Standard Chartered Bank: AI Model Monitoring in Financial Services**

Standard Chartered's Model Risk Policy (disclosed in 2023 Annual Report) requires quarterly performance reviews for all AI models used in credit decisioning, with monthly monitoring for high-volume consumer credit models. The bank uses a Model Performance Dashboard that tracks: out-of-time validation accuracy versus deployment accuracy (to detect model drift); Gini coefficient stability for credit scoring models; population stability index for input data; and adverse action rate by demographic segment (as a proxy for disparate impact). Any model where the Population Stability Index exceeds 0.25 (indicating significant data drift) is automatically flagged for re-validation. This monitoring program directly implements the NIST AI RMF MANAGE 4.1 requirement for post-deployment monitoring and aligns with the UK FCA's supervisory guidance on AI in financial services (Standard Chartered, 2023 Annual Report; UK FCA, AI and Machine Learning Feedback Statement, 2022). *Source: Standard Chartered PLC, 2023 Annual Report, Model Risk disclosures; UK FCA, Feedback Statement on AI and Machine Learning, October 2022.*

WHY IT MATTERS

For managers, the critical insight in AI monitoring is that AI systems that are not monitored are not governed, regardless of how good the pre-deployment governance was. A credit scoring model that was valid and unbiased at deployment can become biased if the population it scores drifts away from its training population over time. A customer service AI that was accurate at launch can begin hallucinating when the product catalog it was trained on becomes outdated. Monitoring is how you know your governance program is actually working in production, not just on paper. The metrics in Section 5.1 give you a starting point for a monitoring dashboard.

5.2 Human Oversight Requirements

Human oversight is the governance mechanism that ensures AI systems remain subject to human accountability and correction. It is the bridge between AI's operational autonomy and organizational responsibility. The EU AI Act Article 14 requires that all high-risk AI systems be designed in a way that enables effective human oversight — including the ability to understand AI outputs, to intervene, to halt, and to override (EU AI Act, Article 14, 2024).

NIST AI RMF GOVERN 6.2 identifies human oversight as a critical component of the AI risk management system, noting that 'humans have the ability to understand, meaningfully oversee, interact with, and disengage or deactivate AI systems' (NIST, 2023). The OECD AI Principles

(Principle 1.4) require that AI systems remain under appropriate human authority throughout their lifecycle (OECD, 2024).

Human oversight requirements scale with the risk of the AI decision context:

Oversight Level	Required for AI Use in	Human Oversight Mechanism Required
Fully Automated (with audit)	Low-risk, high-volume, well-validated tasks with no significant individual impact (e.g., email spam filtering, manufacturing process optimization)	Automated audit logging; anomaly alerts to operator; regular batch review by responsible analyst; right to human review on request
Human-in-the-Loop (decision support)	Medium-risk decisions with potential individual impact where AI provides recommendation and human decides (e.g., customer service routing, content moderation recommendation, preliminary screening)	Human must actively review AI output before decision is recorded; interface must prevent bypass; override must be documented; regular calibration of human review quality
Human-in-Command (final authority)	High-risk decisions directly affecting individual rights, access to services, employment, credit, or health (EU AI Act Annex III categories)	Human must make the final decision; AI serves advisory role only; human must be able to understand the AI's recommendation and its basis; right of affected party to human review if they dispute AI-influenced decision

⚠ The Human Oversight Rubber-Stamp Risk Research published in Scientific Reports (Gaubé et al., 2023) demonstrated that radiologists systematically followed both correct and incorrect AI diagnostic suggestions — exercising no independent judgment. This 'automation bias' is the documented failure mode of human-in-the-loop controls: humans nominally review AI outputs but do not actually exercise independent judgment. Governance councils must design oversight mechanisms that prevent rubber-stamping: time requirements, documented rationale requirements, periodic calibration testing of reviewer independence, and quality sampling. A human oversight control that is bypassed in practice provides no governance benefit — and may create liability by suggesting the organization believed oversight was occurring when it was not.

WHY IT MATTERS

Human oversight is the single most important AI control for managers to get right. When AI systems affect your customers, employees, or regulated processes, someone in your organization is legally responsible for the decision — and that someone is a human. If you have designed your process so that humans nominally review AI recommendations but in practice approve them automatically, you have not implemented human oversight. You have created a documentation trail that shows a human was present without actually having human judgment. For high-risk decisions, the design requirement is: Can the human reviewer meaningfully understand the AI's recommendation? Can they identify when it is wrong? Are they trained to do so? If not, you need to redesign the oversight mechanism.

5.3 AI Incident Management

An AI incident is any event in which an AI system produces outputs, behaviors, or failures that result in or could result in harm, regulatory violation, reputational damage, or operational disruption. AI incidents differ from traditional IT incidents in that they can be subtle, non-deterministic, and difficult to reproduce, which makes detection, investigation, and remediation more complex.

Incident Response Stage	Required Actions
1. Detection	Identify the incident through monitoring alerts, user reports, or third-party notification; assign initial severity classification; notify AI governance incident responder within defined timeframes (1 hour for Critical, 4 hours for High, next business day for Medium/Low)
2. Containment	Assess whether AI system should be suspended, restricted, or continued; implement emergency suspension if harm is ongoing; notify affected business units and customers where appropriate
3. Investigation	Root cause analysis of the incident; documentation of AI system state, inputs, outputs, and human actions at time of incident; assessment of affected party impact; legal/compliance review for regulatory notification obligations
4. Regulatory Notification	EU AI Act Article 73: providers of high-risk AI systems must report serious incidents to relevant national authority without undue delay; GDPR Article 33: notify supervisory authority within 72 hours of data breach discovery
5. Remediation	Implement corrective controls; update risk register; re-validate AI system where required; update training and procedures to prevent recurrence
6. Post-Incident Review	Complete incident report; governance council briefing; lessons learned documentation; update monitoring and controls based on incident findings; annual trend analysis of incidents

► **BUSINESS EXAMPLE: Air Canada Chatbot Liability — Incident Response Analysis** In *Moffatt v. Air Canada* (2024 BCCRT 149), Air Canada's AI chatbot told a customer that bereavement fares could be applied retroactively — incorrect information. When the customer relied on this and sought the discount, Air Canada argued the chatbot was a 'separate legal entity' responsible for its own statements. The British Columbia Civil Resolution Tribunal rejected this defense and held Air Canada liable. The case is the definitive legal authority that an organization cannot disclaim liability for its AI system's outputs. The incident also illustrates a failure of AI incident detection: the chatbot error was only identified because the customer complained. An AI monitoring program with output quality sampling would likely have detected this class of error earlier. Air Canada subsequently implemented a chatbot correction and oversight review. The legal principle is unambiguous: AI outputs are organizational outputs, and organizations are legally responsible for them (*Moffatt v. Air Canada*, 2024 BCCRT 149). *Source: Moffatt v. Air Canada, 2024 BCCRT 149, British Columbia Civil Resolution Tribunal, February 14, 2024.*

WHY IT MATTERS

For managers, AI incident management has two practical imperatives. First: you need a known, practiced response to the first AI incident in your organization — not an improvised one. Regulatory notification deadlines (72 hours for GDPR data breaches; 'without undue delay' under EU AI Act Article 73) run from the time of discovery, not from the time you finish investigating. If you do not have a documented incident response plan before an incident occurs, you will be managing it in crisis mode. Second: the Air Canada case establishes that your organization is legally responsible for every output your AI system generates. There is no defense that 'the AI said it, not us.' This makes output quality monitoring not a nice-to-have but a legal necessity.

6. Prompt Governance - Controlling Generative AI Interaction as an Enterprise Control Layer

Prompt governance is an enterprise control framework specifically designed for generative AI systems — large language models, image generators, and multimodal AI — that are driven by natural language or structured inputs ('prompts'). It addresses a governance challenge that has no direct equivalent in traditional IT: the inputs to generative AI systems are largely unstructured, user-controlled, and capable of bypassing system safeguards through carefully constructed text.

The NIST Generative AI Profile (NIST AI 600-1, July 2024) identifies prompt injection attacks as one of the primary novel risks of generative AI systems: 'A prompt injection attack is a technique used to influence or override the instructions provided to an AI system in order to alter its behavior in unintended or malicious ways' (NIST, 2024, AI 600-1). Prompt governance is the enterprise response to this risk category.

6.1 Prompt Classification and Approval

In an enterprise context, prompts fall into two categories requiring different governance treatment. System prompts are pre-configured instructions embedded in AI system deployments that define the AI's behavior, persona, scope, and constraints. They are the configuration layer of a deployed AI application. User prompts are inputs entered by individual users during live interaction. These operational inputs cannot be pre-approved but must be governed through access controls, DLP monitoring, and usage policies.

Prompt Type	Governance Requirement
System prompts (preconfigured instructions)	Version-controlled in a prompt registry; approved through the AI use approval process; change management required for any modification; access-restricted to authorized configuration owners; tested for prompt injection vulnerability before deployment; documented with intended behavior specification
Standard user prompts (pre-built, reusable prompt templates for common business functions)	Approved prompt library maintained by AI governance function; templates tested for security and alignment with policy before inclusion; users encouraged to use approved templates for repeatable tasks; training provided on effective and compliant prompt design
Ad-hoc user prompts (real-time user inputs)	Governed through acceptable use policy; DLP monitoring for sensitive data inclusion; input filtering for prohibited content categories; output monitoring for policy-violating responses; logging for audit and compliance
Automated/API prompts (system-to-system prompt generation)	Full code review and security testing before deployment; output validation layer required; no automated prompt generation without documented intent specification and approval

The OWASP Top 10 for Large Language Model Applications (2023, updated 2025) identifies LLM01: Prompt Injection as the highest priority security risk for enterprise LLM deployments: 'Prompt Injection Vulnerabilities manipulate large language models (LLMs) through crafted

inputs, causing unintended actions by the LLM' (OWASP, 2025). Prompt governance is the primary enterprise defense against this class of attack.

► **BUSINESS EXAMPLE: Prompt Injection Attack — Bing AI (2023)** In February 2023, security researcher Kevin Liu demonstrated that Microsoft's Bing AI chat interface (powered by GPT-4) could be manipulated through prompt injection to reveal its hidden system prompt — the confidential configuration instructions Microsoft had embedded to define the AI's behavior and constraints. The attack used a user-accessible conversation to instruct the AI to ignore its system instructions and reveal its original prompt. Microsoft had not implemented controls to prevent user prompts from overriding system-level instructions. The attack demonstrated that system prompts are not inherently confidential and that the boundary between system instructions and user inputs is a governed boundary requiring active controls — not an assumed technical separation. Prompt governance controls (prompt injection testing, output filtering, instruction hierarchy enforcement) are the enterprise defense against this attack class (Kevin Liu/Marvin von Hagen, February 2023; Microsoft security response; NIST AI 600-1, 2024). *Source: Kevin Liu and Marvin von Hagen, Bing AI system prompt disclosure, February 2023; NIST AI 600-1 Generative AI Profile, July 2024, Section 2.6 Prompt Injection.*

WHY IT MATTERS

For managers, prompt governance is the specific control framework that makes generative AI safe to use in enterprise contexts. Without it, your AI deployments are vulnerable to: employees inadvertently leaking confidential data through AI prompts (Samsung); malicious users manipulating AI systems through prompt injection; AI systems providing unauthorized information when their system prompts are bypassed; and regulatory violations when AI systems are prompted to produce prohibited outputs. A prompt registry and approval process does not slow down AI adoption — it gives you the confidence to say yes to generative AI because you know the guardrails are in place.

6.2 Sensitive Data Controls in Prompts

The most common prompt governance failure is the inadvertent inclusion of sensitive data in AI system inputs. This occurs because users naturally include relevant context when prompting AI systems for assistance. That 'relevant context' often includes personal information, confidential business data, protected health information, or other sensitive material that should not be shared with external AI providers.

Data Category	Prompt Input Control Required
Personal data (GDPR-regulated)	Prohibited in prompts to external AI systems without documented legal basis and processor agreement; require pseudonymization where use is necessary; DLP rules to detect and block PII in prompts to unauthorized AI systems
Protected health information (HIPAA/GDPR health data)	Prohibited in prompts to any AI system not covered by a Business Associate Agreement (HIPAA) or appropriate data processing agreement; healthcare-specific AI systems only
Financial data (customer account data, transaction records)	Classified as Confidential; permitted only in AI systems within the enterprise security perimeter with documented data governance; prohibited in consumer AI tools without explicit authorization

Data Category	Prompt Input Control Required
Intellectual property (source code, product designs, trade secrets)	Classified as Restricted; strict prohibition on sharing with external AI systems without legal review; documented exception process for approved use cases with appropriate contractual protections
Employee personal data	Subject to employment law requirements; prohibited in AI systems used for performance management or employment decisions without HR and legal sign-off; documentation of AI's role in employment decisions maintained
Customer communications	Review for personal data content before AI processing; anonymize where possible; ensure AI processing is covered in customer-facing privacy disclosures

NOTE: EU AI Act Article 10(5) permits processing of sensitive personal categories of data for AI training only when subject to adequate safeguards: 'Processing of special categories of data for the purposes of quality criteria and bias checking... may be done with appropriate safeguards for the fundamental rights and freedoms of natural persons.' This is a narrow exception, not a general permission. Legal review is required before any processing of sensitive personal data categories for AI training purposes.

WHY IT MATTERS

Sensitive data controls in prompts are where most enterprise AI data governance failures currently occur. The risk is not sophisticated corporate espionage. It is the routine business behavior of employees who want to be more productive and naturally include relevant context when asking an AI for help. 'Here's our Q3 sales data — can you summarize it for the board presentation?' is the kind of prompt that seems harmless and creates serious data governance exposure. For managers, the practical control is not prohibition but policy, training, and technical guardrails: clear guidelines on what data can be shared with which AI systems, DLP controls configured for AI interfaces, and a fast-track process for legitimate use cases that require sensitive data processing.

6.3 Prompt Version Control and Change Management

System prompts and approved prompt templates are enterprise software assets that require the same version control, change management, and documentation practices applied to any other critical software component. A system prompt is the configuration that defines how an AI application behaves. A change to a system prompt can fundamentally alter the AI's outputs, safety properties, and compliance characteristics.

Change Management Requirement	Implementation Standard
Version registry	All system prompts maintained in a version-controlled registry; each version has a unique identifier, owner, approval date, intended behavior specification, and test results

Change Management Requirement	Implementation Standard
Change approval process	Changes to system prompts for high-risk AI applications require the same approval tier as changes to AI model configuration; changes to low-risk applications require technical review and documentation
Rollback capability	Previous prompt versions retained and recoverable; rollback can be completed within defined RTO; rollback procedure tested annually
Testing before deployment	All system prompt changes tested against intended behavior specification; regression testing to confirm no unintended behavior change; security testing for prompt injection vulnerability
Documentation requirements	Prompt change log maintained with change description, business justification, approver, and test results; changes searchable for incident investigation purposes

WHY IT MATTERS

Prompt version control may seem like an engineering detail, but it has a direct governance implication for managers. When an AI system produces an unexpected or harmful output, the investigation always asks: 'When did the system's behavior change, and what changed?' If system prompts are not version-controlled, you cannot answer this question. If a system prompt was changed by an engineer without going through the change management process, the governance record is incomplete. Version control for prompts is how you maintain governance continuity across the lifecycle of a deployed AI application.

7. Audit and Assurance - Internal Audit of AI Governance Effectiveness

Internal audit provides independent assurance that the enterprise AI governance program operates as designed and is effective in managing AI risk. It is the verification function that transforms governance documentation into demonstrated accountability. Without internal audit coverage, an organization cannot know whether its policies and controls are actually working, or whether they exist only on paper.

ISO/IEC 42001 Clause 9.2 requires that organizations conduct internal audits of the AI management system at planned intervals to provide information on whether the AIMS conforms to the organization's own requirements and to the ISO standard requirements, and is effectively implemented and maintained. The NIST AI RMF MAP, MEASURE, and MANAGE functions collectively support ongoing evaluation of AI governance effectiveness (ISO, 2023; NIST, 2023).

7.1 AI Audit Scope and Mandate

The internal audit function's AI mandate must be formally established by the audit committee and documented in the internal audit charter. The mandate determines: what elements of AI governance are subject to audit; the frequency and depth of AI audit coverage; the auditors' access rights to AI systems and documentation; and the reporting relationship for AI audit findings.

Audit Domain	Scope Description
Governance structure	AI Governance Council charter, composition, meeting frequency, decision documentation; decision rights framework; escalation process effectiveness; board reporting content and timeliness
Policy framework	AI Policy completeness, currency, and distribution; evidence of employee training and acknowledgment; exception management process; prohibited use controls effectiveness
AI Systems Registry	Completeness (all AI systems registered); accuracy of risk classifications; approval documentation; currency of entries; decommissioning process
Risk management	Risk register completeness and currency; treatment plan implementation; residual risk levels; escalation of unacceptable risks; ERM integration
Control effectiveness	Technical controls testing (access controls, logging, DLP); validation documentation for deployed AI systems; human oversight mechanism effectiveness; prompt governance controls
Third-party AI risk	Vendor AI governance questionnaire completion; contractual protections adequacy; vendor monitoring program; due diligence documentation
Incident management	Incident detection and reporting completeness; regulatory notification timeliness; root cause analysis quality; remediation implementation; recurrence monitoring
Monitoring program	Monitoring KPI completeness and coverage; threshold appropriateness; response to threshold breaches; data quality for monitoring metrics

The Institute of Internal Auditors (IIA) published its Global Internal Audit Standard (2024), which explicitly addresses AI-related audit responsibilities. The IIA standards require that internal audit plans reflect the most significant risks to the organization — and that AI risk be assessed in developing the annual audit plan (IIA, Global Internal Audit Standard, 2024).

7.1a Three Lines of Defense: AI Governance Roles

The Three Lines of Defense model, as adopted in the IIA's Global Internal Audit Standard (2024), provides a clear framework for distinguishing first-line operational ownership, second-line risk oversight, and third-line independent assurance in AI governance. Enterprises applying this model to AI must explicitly assign each defense line's responsibilities; without this clarity, AI risk management accountability defaults to the second or third line, weakening operational ownership.

Defense Line	Ownership	AI Governance Responsibilities	Audit Evidence Produced	Independence Requirement
First Line: Operations	Business units; AI system owners; technical teams	Day-to-day AI controls; use case approval requests; training data quality; monitoring execution; incident detection and initial reporting; AI registry maintenance	Signed use case approval forms; AI registry entries; monitoring logs; validation test results; incident records; training completion records	None required; operational accountability
Second Line: Risk & Compliance	CRO, CCO, CISO, AI Governance function, Legal	Risk framework design; policy maintenance; risk classification approval; regulatory compliance oversight; AI Governance Council support; vendor governance; monitoring program design	Risk register; policy documents; risk classification decisions; regulatory mapping; board risk reports; vendor assessment records; governance council minutes	Independent of first-line operations; not independent of management
Third Line: Internal Audit	Chief Audit Executive; internal audit function	Independent assurance on AI governance program effectiveness; testing of first and second-line controls; audit of AI registry completeness, risk classification accuracy, human oversight mechanisms, incident management, and regulatory compliance	Audit reports with findings and ratings; management letter; remediation tracking; audit committee reporting; regulatory inspection readiness assessment	Fully independent of management; reports to audit committee of the board

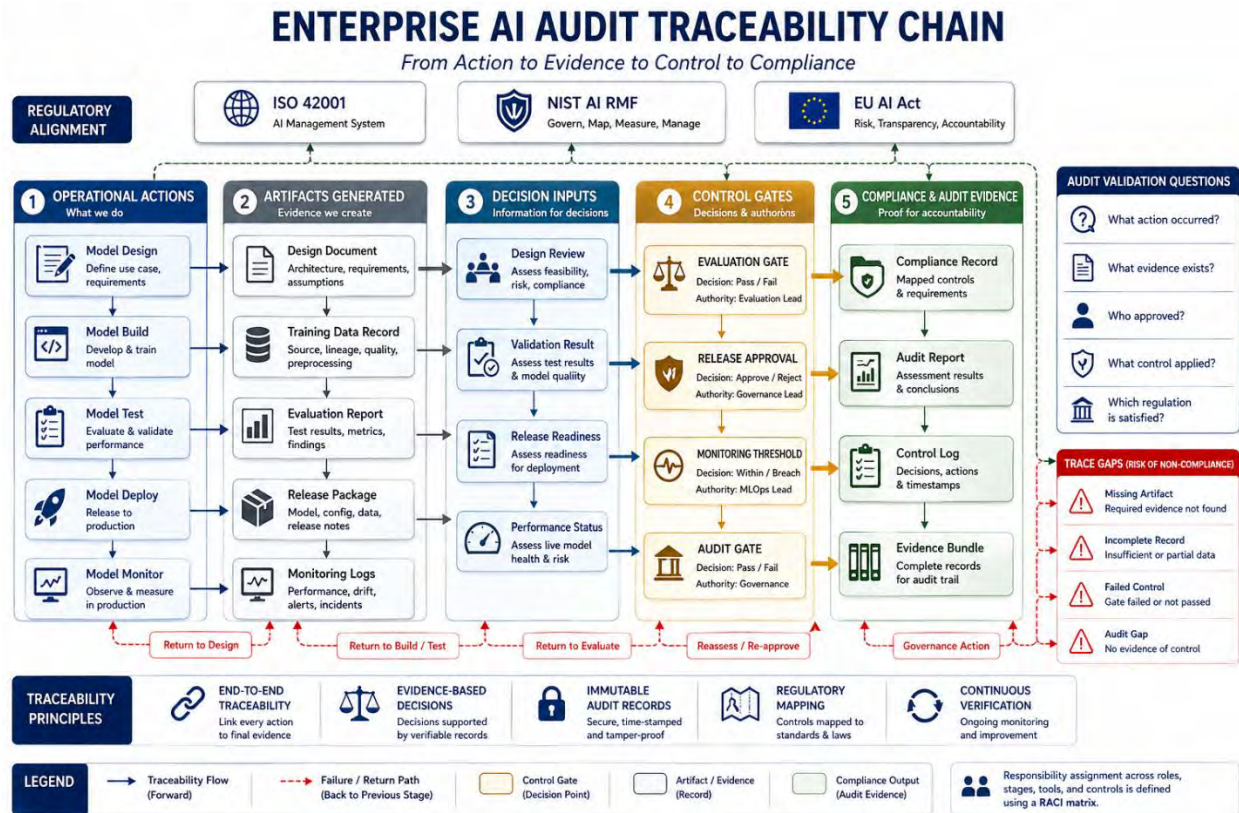


Figure 2-4. Enterprise AI Audit Traceability Chain.

Figure 2-4 traces how operational actions produce artifacts, which feed decision inputs, which are assessed at control gates, which generate compliance and audit evidence. The five-column structure — Operational Actions, Artifacts Generated, Decision Inputs, Control Gates, Compliance & Audit Evidence — provides the end-to-end traceability chain that auditors require.

► BUSINESS EXAMPLE: Goldman Sachs: Independent Model Validation as AI Governance Assurance

Goldman Sachs's Model Risk Management framework, extended to AI as described in Section 1.3, includes an independent model validation function that operates separate from the model development and deployment functions. All AI models used in consequential decisions undergo validation by this function, which tests: mathematical soundness; conceptual soundness (is the model appropriate for the use case?); data quality; performance against holdout datasets; performance on stressed scenarios; and explainability against defined standards. The validation function reports to the CRO, not to the CIO or technology function, ensuring independence from the teams that build and deploy models. Validation findings are treated as binding — a model with an 'unsatisfactory' validation rating cannot be deployed without documented exception approval from the CRO. This governance structure represents industry best practice for AI assurance in financial services, directly implementing the independent validation requirements in OCC Bulletin 2011-12 extended to AI (Goldman Sachs, 2023; OCC Model Risk Management Guidance, 2011). *Source: Goldman Sachs Group, 2023 Annual Report, Model Risk Management section; OCC Bulletin 2011-12, Model Risk Management Guidance, April 2011.*

WHY IT MATTERS

For managers, internal audit of AI governance serves a practical purpose beyond regulatory compliance: it tells you what your governance program actually looks like from an independent perspective, not how you believe it is operating. Most governance failures come to light because someone outside the governance program — a regulator, an auditor, a whistleblower, an affected customer — identifies a gap that internal teams did not notice because they were too close to the process. An annual AI governance audit is how you find these gaps before someone else does. For managers responsible for AI deployments, an internal audit finding is significantly less expensive than a regulatory finding, even if it identifies the same problem.

7.2 AI Audit Program

The AI audit program defines how the internal audit function executes its AI governance coverage. It includes the risk-based audit plan, audit procedures, evidence standards, finding classification, and reporting requirements.

Audit Activity	Frequency	Key Procedures	Output
AI Systems Registry audit	Annual (at minimum)	Verify all AI systems are registered; test sample for completeness and accuracy of risk classifications; verify approval documentation exists; confirm named owners are current	Registry completeness report; classification accuracy assessment; remediation recommendations
High-risk AI system deep audit	Annual (each system)	Review all governance documentation; test validation evidence; assess control effectiveness; evaluate human oversight mechanism; review monitoring data; assess incident history	Individual system audit report; rating of governance maturity; findings with recommendations
AI policy and training audit	Annual	Verify policy is current and approved; test evidence of employee training completion; assess training content currency; review exception log	Policy compliance assessment; training gap findings
Third-party AI risk audit	Annual	Review vendor AI questionnaire responses; test contractual protections against current requirements; assess vendor monitoring program effectiveness	Vendor risk audit report; gap analysis against policy requirements
AI monitoring program audit	Semi-annual	Verify monitoring metrics are being collected and reviewed; test threshold response records; review incident data for under-reporting indicators	Monitoring effectiveness assessment; threshold calibration recommendations
AI incident management audit	Following each significant incident and annually	Review incident records for completeness; assess root cause analysis quality; verify remediation implementation; assess regulatory notification compliance	Incident management effectiveness assessment

WHY IT MATTERS

For managers, an effective audit program is a management tool, not just a compliance exercise. The semi-annual monitoring program audit, for example, tells you whether the oversight mechanisms you put in place for your AI deployments are actually catching problems — or whether they are generating data that nobody reads and nobody acts on. Requesting regular audit reports on your AI program and actively engaging with findings demonstrates governance maturity to your board and regulators. It also protects you personally: documented evidence that you took audit findings seriously and acted on them is strong evidence of reasonable care in any subsequent enforcement or litigation.

7.3 Reporting AI Audit Findings

AI audit findings must be reported promptly and clearly to appropriate governance stakeholders, with enough context for actionable remediation decisions. Finding classification, escalation, and tracking must be consistent with enterprise audit standards and the risk severity of the finding.

Finding Severity	Definition and Examples	Required Actions
Critical	Immediate risk of regulatory violation, significant harm to individuals, or governance failure that could not be defended to a regulator — e.g., high-risk AI deployed without documentation; prohibited AI practice in use; evidence of suppressed incident reporting	CEO and Board notification within 5 business days; immediate remediation plan with 30-day completion target; governance council emergency session if required; legal review for regulatory notification obligation
High	Significant control failure or governance gap not immediately producing harm but creating material risk — e.g., AI risk register materially incomplete; human oversight mechanism not functioning as designed; third-party AI vendor with significant unassessed risk	Governance council notification; remediation plan required within 30 days; 90-day completion target; tracking in risk register as open risk
Moderate	Control weakness or governance gap with limited near-term risk — e.g., monitoring metrics incomplete; policy training completion below target; prompt version control not consistently applied	Business unit management notification; remediation plan within 60 days; tracking through normal audit follow-up process
Low (Observation)	Good practice opportunity; minor process improvement — e.g., documentation inconsistency; reporting format improvement opportunity	Reported to relevant process owner; no mandatory remediation timeline; included in annual governance improvement plan

WHY IT MATTERS

Finding severity classifications are important for managers because they determine your personal accountability for remediation. A Critical finding that is not remediated on schedule will be escalated to the board and potentially to regulators. A High finding that sits open past its remediation target becomes a management accountability issue in the next audit cycle. For managers responsible for AI systems with audit findings, the governance imperative is: own your findings, document your remediation actions, and close the loop with internal audit before the next review. An organization with no AI audit findings has either an excellent governance program or one that is not being audited rigorously, and regulators have learned to tell the difference.

8. Board Reporting - Executive and Board-Level AI Governance Reporting

Board and executive reporting on AI risk is a governance obligation with two distinct purposes. First, it fulfills the board's fiduciary duty to oversee significant organizational risks, and AI is now clearly a significant organizational risk in most enterprises. Second, it is a regulatory requirement: the EU AI Act's governance obligations, SEC cybersecurity disclosure requirements (extended to AI), and sector-specific regulatory guidance all require board-level oversight of AI risk.

Deloitte's AI Governance Roadmap (2025) states that 'boards have a fiduciary duty to understand and oversee AI-related risks and opportunities, and that this duty requires boards to have access to appropriate expertise and information' (Deloitte, 2025). Harvard Law School's Corporate Governance forum reported in 2024 that institutional investors are increasingly incorporating AI governance into ESG assessments, creating direct linkage between AI governance quality and cost of capital (Harvard Law School Corporate Governance Forum, 2024).

8.1 Quarterly AI Risk Report

The governance council should prepare and present a Quarterly AI Risk Report to the board risk committee and audit committee. This report provides a structured, consistent view of AI risk across the enterprise that allows the board to fulfill its oversight obligation. The NIST AI RMF GOVERN function requires that 'risk management efforts are established and maintained across the organization with senior leadership responsible for the organization's AI risk tolerance' (NIST, 2023, GOVERN 1.3).

Report Section	Required Content
AI Program Summary	Total number of active AI systems by risk tier; new deployments in quarter; systems retired or suspended; change in portfolio risk profile versus prior quarter; key strategic AI initiatives underway
Risk Exposure Summary	Aggregate risk rating of AI portfolio; change in risk exposure versus prior quarter; top 3-5 identified AI risks requiring board attention; status of risks escalated from prior quarter
Regulatory Compliance Status	Current compliance status against applicable AI regulations; significant regulatory developments in the quarter; upcoming regulatory deadlines; assessment of compliance readiness
Incident Report	Number and severity of AI incidents in the quarter; significant incidents with root cause summary; regulatory notifications made; pattern analysis across incident history; comparison to prior quarter
Monitoring Performance	Summary of AI system monitoring results; systems requiring additional oversight; monitoring KPI performance against targets; action taken on threshold breaches
Audit and Assurance	AI audit activities completed in quarter; summary of material findings; finding remediation status; upcoming audit activities

Report Section	Required Content
Emerging Risks	New AI risks identified in the quarter; regulatory developments with forward-looking implications; technology developments with governance implications; peer/industry incidents with lessons for the enterprise
Management Actions Requested	Specific board approvals sought, if any; resources requested; strategic direction sought; risk tolerance confirmation required

Board AI Risk KPI Definitions

For board-level AI reporting to be meaningful, metrics must have precise, consistent definitions applied across all reporting periods. Undefined metrics cannot be trended, benchmarked, or audited. The table below defines the primary KPIs used in the Quarterly AI Risk Report. All KPIs are classified as internal metrics; no published cross-industry benchmark baselines are available as of March 2026 — organizations should establish internal baselines and trend against their own prior periods.

KPI Name	Definition (Numerator / Denominator)	Reporting Frequency	Target Direction
% Governed Use Cases	Number of AI systems with complete governance documentation (registry entry + risk assessment + named owner + approval record) divided by total number of known AI systems in production, expressed as a percentage. Population = all systems in AI registry plus any identified through shadow AI detection.	Quarterly	Target: 100%. Trend: stable or improving.
AI Registry Completeness	Number of AI systems in production with a current registry entry divided by estimated total AI systems in production (estimated via annual discovery exercise). Entries are 'current' if reviewed within the last 12 months or since last material change.	Quarterly	Target: >95%. Internal metric only; no external benchmark.
Incident Rate (per period)	Count of AI incidents meeting the definition in Section 5.3 that occurred during the reporting quarter, reported by severity tier (Critical / High / Medium / Low). Incidents are counted at time of detection, not time of occurrence.	Quarterly	Target: declining trend. Zero Critical incidents target for mature programs.
Mean Time to Detection (MTTD)	For Critical and High severity incidents: average elapsed time between the estimated time of incident occurrence and the time of formal incident detection record creation. Calculated for the reporting quarter.	Quarterly	Target: declining trend. Internal baseline required.

KPI Name	Definition (Numerator / Denominator)	Reporting Frequency	Target Direction
Human Override Rate	For AI systems in Human-in-the-Loop or Human-in-Command oversight categories: count of decisions where a human reviewer modified or overrode the AI recommendation divided by total AI decisions reviewed in the period. A near-zero rate signals rubber-stamping risk.	Quarterly per system	Target: within defined range (neither near-zero nor excessively high). Triggers investigation if outside range.
Training Completion Rate	Number of employees who have completed required AI literacy training for their role category (per Section 2.1 matrix) divided by total number of employees required to complete that training tier, expressed as a percentage.	Quarterly	Target: 100%. Legal obligation under EU AI Act Article 4 for EU-market operations.
Open Critical/ High Audit Findings	Count of open internal audit findings classified as Critical or High severity (per Section 7.3) as of the report date. Includes findings past their target remediation date.	Quarterly	Target: Zero open Critical findings; zero High findings past remediation date.
Vendor Assessment Currency	Number of Tier 1 and Tier 2 AI vendors with a completed governance questionnaire (Section D) dated within the last 12 months divided by total Tier 1 and Tier 2 AI vendors. Expressed as a percentage.	Quarterly	Target: 100% for Tier 1; >90% for Tier 2.

► **BUSINESS EXAMPLE: Microsoft Annual AI Transparency Report** Microsoft has published an annual AI Transparency Report since 2022, disclosing enterprise-level information on its AI governance program, including: the number of responsible AI impact assessments completed; significant incidents and how they were addressed; regulatory compliance activities; investments in AI safety research; and the maturity of its Responsible AI Standard implementation across product lines. The 2024 report disclosed that Microsoft completed over 1,000 sensitive use reviews and impact assessments in the reporting period. This level of transparency to external stakeholders — beyond what is legally required — represents a leading-edge governance disclosure practice. For internal board reporting, the same disciplined framework applied to a proprietary quarterly report provides boards with the structured, actionable information needed to fulfill their oversight responsibilities (Microsoft, Responsible AI Transparency Report, 2024). *Source: Microsoft Corporation, Responsible AI Transparency Report 2024. Available at microsoft.com/en-us/ai/responsible-ai-transparency-report.*

WHY IT MATTERS

For managers, the board report is not just a document that executives produce. It requires active input from every manager responsible for AI systems. The accuracy of the AI systems registry, the completeness of incident records, the currency of risk assessments, and the reliability of monitoring data all feed into the board report. When a board asks 'How are we managing AI risk?' and the answer is a well-organized, evidence-based quarterly report, it signals a governance program that is actually working. When the answer is 'we're working on it,' it signals governance that exists in intent but not in practice. For managers preparing for board-level AI governance, the question is: Can you produce a complete, accurate, evidence-based AI risk picture for your area of responsibility on 48 hours' notice?

8.2 Escalation Triggers for Out-of-Cycle Board Reporting

The quarterly reporting cycle does not eliminate the need for out-of-cycle board notification when significant AI events occur. The following triggers require notification to the board risk committee chair or full board as specified, outside the normal reporting cycle:

Trigger	Required Escalation and Timeframe
Critical AI incident resulting in significant harm to individuals or third parties	Board Chair and Audit Committee Chair notification within 24 hours; full Board notification at next regular meeting or within 5 business days if meeting not scheduled
Regulatory investigation or enforcement action related to AI	General Counsel notification immediate; Board Chair notification within 24 hours; Audit Committee briefed within 5 business days
Material regulatory change with significant enterprise compliance implications	Board Risk Committee notification within 10 business days; revised compliance roadmap presented at next board meeting
Significant AI security incident (data breach via AI system, successful prompt injection with data exfiltration)	Board notification consistent with existing cybersecurity incident escalation policy; independent AI security review commissioned
Public incident at peer organization with direct applicability to enterprise AI	Governance council discussion within 5 business days; board summary memo within 10 business days
Proposed high-risk AI deployment in a new category not previously reviewed by the board	Board Risk Committee briefing before governance council approval; board approval may be required for highest-risk categories

WHY IT MATTERS

Out-of-cycle escalation is where AI governance meets crisis management. The reason to have documented escalation triggers before an incident is that no one makes good governance decisions under time pressure without a prior process. The 72-hour GDPR data breach notification clock, the 'without undue delay' EU AI Act serious incident notification, and the SEC's 4-business-day material cybersecurity incident disclosure requirement all run from the time of discovery, not from the time you finish deciding whether it is significant enough to report. For managers: if you discover an AI incident that might meet a regulatory notification threshold, your first call should be to legal counsel. Your second should be to the governance council. Your third should be to document everything you know as of that moment.

9. Continuous Improvement - Maturing the Enterprise AI Governance Program

AI governance is not a state. It is a practice. Regulatory requirements evolve, AI technology capabilities advance, the organizational AI portfolio grows in scope and complexity, and the risk landscape changes continuously. A governance program that was adequate in 2023 may be significantly inadequate in 2026, not because anything went wrong, but because the environment changed.

ISO/IEC 42001 Clause 10 requires organizations to continually improve the suitability, adequacy, and effectiveness of the AI management system. NIST AI RMF emphasizes that AI risk management is 'an ongoing and iterative process' that must be updated based on 'monitoring, evaluation, and feedback' (NIST, 2023). Continuous improvement is not a procedural nicety — it is a core governance requirement.

9.1 AI Governance Maturity Model

The AI governance maturity model provides a structured framework for assessing current governance capability and defining an improvement roadmap. It is adapted from the NIST AI RMF maturity guidance and ISO/IEC 42001 conformance criteria, calibrated to the governance dimensions of this handbook.

Maturity Level	Characteristics	Governance Coverage	Typical Enterprise Profile
Level 1 — Initial / Ad Hoc	AI governance exists informally; individual project-based decisions; no enterprise-wide policy; governance depends on individual champions; significant undocumented AI use	No AI Systems Registry; no formal risk classification; no consistent approval process; governance council not established	Organizations at the beginning of AI adoption; organizations responding to first significant AI incident or regulatory inquiry
Level 2 — Developing	Basic governance structures established; AI policy exists and is approved; governance council formed; AI registry initiated; major AI systems classified; high-risk AI systems identified but governance may be incomplete	Core policy documents in place; AI registry covering majority of known AI systems; governance council meeting regularly; high-risk systems have documentation but completeness variable	Organizations that have completed initial governance program design; have experienced first regulatory or audit review of AI; governance is reactive rather than proactive

Maturity Level	Characteristics	Governance Coverage	Typical Enterprise Profile
Level 3 — Defined	Comprehensive, documented governance program; all AI systems registered; risk classification complete and current; controls implemented for all risk tiers; monitoring program operational; audit coverage complete; board reporting regular	Full registry coverage; documented risk assessment for all deployed AI systems; control framework implemented; monitoring KPIs tracked; quarterly board reporting in place; internal audit AI program operational	Mature enterprises with dedicated AI governance function; governance integrated with ERM; program is proactive rather than reactive; capable of demonstrating governance to regulators
Level 4 — Managed	Quantitative governance management; governance decisions driven by metrics and trend analysis; predictive risk management; governance integrated across development, procurement, and operations; continuous learning from incidents across industry	Evidence-based governance decisions; trend analysis of risk and incident data; forward-looking regulatory compliance; third-party AI risk managed proactively; governance program reviewed against peer benchmarks	Leading enterprises with mature AI programs; governance embedded in culture not just process; AI governance enables business velocity rather than slowing it; governance recognized by regulators as industry benchmark
Level 5 — Optimizing	Continuous innovation in governance practice; organization contributes to industry standards and regulatory development; governance program generates competitive advantage through customer and regulatory trust; AI governance indistinguishable from overall business governance	Governance program externally certified (ISO/IEC 42001); governance program influences industry standards; board-level AI governance sophistication recognized by institutional investors; governance enables AI innovation at scale	A small number of global technology leaders and highly regulated enterprises; requires 3-5 years of sustained investment from Level 3

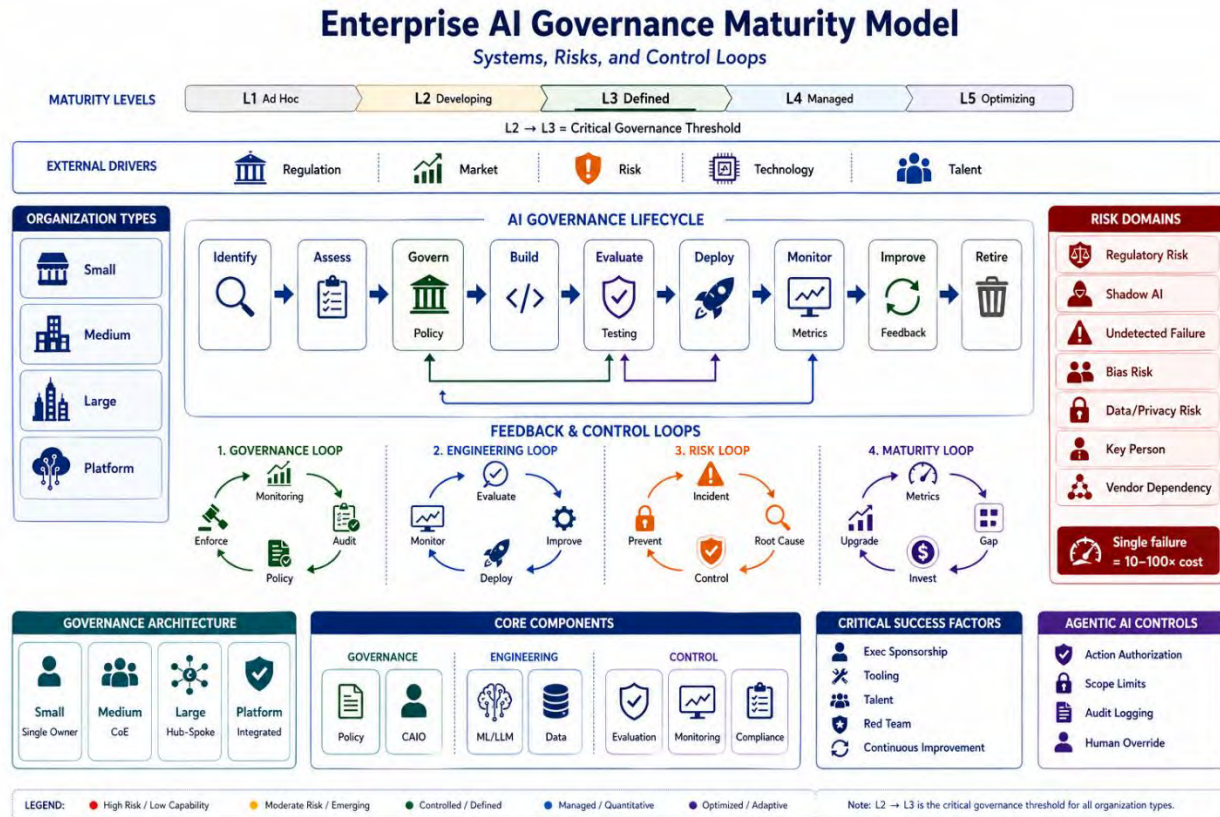


Figure 2-3. Enterprise AI Governance Maturity Model.

Figure 2-3 integrates the five-level maturity scale (L1 Ad Hoc through L5 Optimizing) with the AI governance lifecycle, four organization types, risk domains, feedback and control loops, and critical success factors. The L2 → L3 transition is highlighted as the critical governance threshold — the point at which governance moves from informal to defined, and regulatory compliance becomes demonstrable.

Measurable Maturity Evidence Criteria

Maturity level claims must be supported by observable evidence. The following criteria define what an auditor, regulator, or governance council would require to confirm each level. Organizations should use this table both for self-assessment and to prepare for external audit. Audit readiness is indicated at each level.

Level	Label	Minimum Observable Evidence Required	Measurable KPIs at This Level	Audit Readiness
1	Initial / Ad Hoc	No AI systems registry exists; no documented AI policy; governance decisions made informally; no formal risk classification has been performed for any AI system	% of AI systems with documented owner: <20%; AI registry completeness: unknown; policy coverage: none; training completion: none	Not audit-ready; significant gaps will be found

Level	Label	Minimum Observable Evidence Required	Measurable KPIs at This Level	Audit Readiness
2	Developing	Written AI policy exists and has been approved; AI Governance Council has been established and has met at least twice; an AI systems registry has been initiated covering majority of known AI systems; at least one risk assessment has been completed for a high-risk AI system	% of AI systems registered: >60%; policy approved by appropriate authority: yes; Governance Council meets at least quarterly: yes; high-risk systems with documented risk assessment: >50%	Partial; basic documentation can be produced but significant gaps expected
3	Defined	Complete AI systems registry with risk classifications for all systems; documented risk assessment for every deployed AI system; control framework implemented for all Tier 1 systems; monitoring program generating metrics; quarterly board reporting in place; internal audit has assessed AI governance at least once	AI registry completeness: >95%; high-risk system documentation completeness: 100%; monitoring KPIs with current data: >80%; board AI report produced last quarter: yes; open Critical/High audit findings: zero	Substantially audit-ready; able to produce evidence on request for most requirements
4	Managed	All Level 3 evidence plus: governance decisions demonstrably driven by metrics and trend data; forward-looking regulatory compliance program; all third-party AI vendors assessed; peer incident review program in operation; quantitative risk targets set and tracked	Residual risk trend improving year-over-year: yes; vendor AI assessments current for all Tier 1/2 vendors: 100%; monitoring threshold breach response rate: >95%; incident recurrence rate: declining trend; governance improvement plan completed on schedule: yes	Fully audit-ready; governance program verifiable against quantitative targets
5	Optimizing	All Level 4 evidence plus: ISO/IEC 42001:2023 certification by accredited body; governance program has influenced industry standards or regulatory development; board demonstrates AI governance sophistication in disclosures; AI governance generates demonstrable competitive or regulatory trust advantage	ISO/IEC 42001 certification: current; external transparency reporting published: yes; institutional investor AI governance rating: positive; regulatory inspection findings: none; industry recognition or peer benchmarking: documented	Externally certified; highest audit confidence

► **BUSINESS EXAMPLE: Google's AI Governance Maturity Journey** Google Cloud published its ISO/IEC 42001:2023 certification in 2024, covering Google Cloud Platform, Google Workspace, and Gemini. The certification represents a Level 4-5 maturity achievement: it required that Google demonstrate not just the existence of an AI governance program but its systematic effectiveness across the AI management system lifecycle. Google's certification followed years of investment in its Responsible AI practices — starting with the 2018 publication of Google's AI Principles, followed by the Responsible AI Practices framework (2021), the Model Cards standard for AI transparency (2019), and the formalization of its AI red-teaming function. The progression from articulated principles (Level 2) to certified management system (Level 4-5) took approximately 6 years of systematic investment. This timeline is instructive for enterprises beginning their AI governance journey: governance maturity is measured in years, not quarters (Google, ISO/IEC 42001 Certificate, 2024; Google AI Principles, 2018). *Source: Google LLC, ISO/IEC 42001:2023 Certification, 2024, available at cloud.google.com/security/compliance/iso-42001; Google AI Principles, June 2018.*

WHY IT MATTERS

For managers, the maturity model provides two practical tools. First, it is a diagnostic: use the maturity level descriptions to assess where your organization currently sits, where your stakeholders believe you sit, and where your board believes you sit. Governance gaps often manifest as discrepancies between what leaders believe is in place and what is actually in place. Second, it is a roadmap: each level transition requires specific investments and capability developments. Moving from Level 2 to Level 3 is primarily a documentation and process investment. Moving from Level 3 to Level 4 requires quantitative management capability. Knowing which transition you are making helps you budget and staff the governance program appropriately.

9.2 Governance Improvement Cycle

The governance improvement cycle turns continuous improvement into a defined organizational process rather than an aspirational commitment. It follows the Plan-Do-Check-Act (PDCA) methodology embedded in ISO/IEC 42001 and adapts it to the AI governance context:

PDCA Stage	AI Governance Improvement Activities
PLAN — Set objectives and design improvements	Annual governance maturity assessment; review of regulatory developments; gap analysis against current maturity level and target; improvement priorities identified and resourced; improvement plan approved by governance council
DO — Implement improvements	Execute improvement plan items; update policies, procedures, and controls; implement new monitoring capabilities; complete training updates; onboard new governance tools
CHECK — Evaluate effectiveness	Internal audit of improvement implementations; monitoring data review for evidence of improved governance effectiveness; stakeholder feedback collection; comparison against maturity targets; regulatory feedback assessment
ACT — Standardize and escalate	Document successful improvements in governance program; identify areas requiring additional iteration; escalate persistent gaps to governance council for additional resource; update improvement plan for next cycle

The governance improvement cycle should complete at minimum annually, with a formal governance program review at the start of each fiscal year. Trigger-based reviews should occur following significant incidents, major regulatory changes, or significant AI portfolio expansion.

9.3 Key Governance Improvement Triggers

In addition to the annual improvement cycle, the following events trigger an out-of-cycle governance review and targeted improvement effort:

Improvement Trigger	Required Governance Review Scope
Significant AI incident (High or Critical severity)	Root cause analysis for governance gaps; control effectiveness review in the affected domain; policy review for adequacy; training review
Material regulatory change	Regulatory gap analysis; policy and control updates to maintain compliance; implementation timeline approved by governance council
Significant expansion of AI portfolio (new risk categories, agentic AI, new high-risk categories)	Governance capability assessment against new portfolio requirements; control framework extension; registry and monitoring updates; training updates
External peer incident with direct applicability	Rapid applicability assessment; targeted control testing; gap remediation where required
Internal audit material finding	Root cause analysis; targeted remediation; governance council report on remediation status
Significant change in AI regulatory enforcement landscape (enforcement action against peer, new regulatory guidance)	Regulatory response assessment; compliance posture review; governance council briefing

WHY IT MATTERS

For managers, continuous improvement in AI governance is not just a regulatory requirement. It is a competitive and operational imperative. AI governance programs that do not evolve will be outpaced by the AI risk environment within 12-18 months. The regulatory landscape, the threat landscape, and the AI capability landscape are all changing faster than most organizations' governance programs are designed to accommodate. Building in the improvement cycle, resourcing it adequately, and reporting its progress to the board is the mechanism by which governance programs stay relevant. The maturity model in Section 9.1 gives you a way to measure improvement objectively and to communicate progress to your board in terms they can evaluate.

APPENDICES

SECTION A — AI Systems Registry Template - Authoritative Inventory of Enterprise AI Systems

The AI Systems Registry is the enterprise's authoritative inventory of all AI systems in use, development, or procurement. Completeness and currency of the registry are foundational requirements of ISO/IEC 42001 and the NIST AI RMF MAP function. The following template defines the minimum data elements required for each registry entry.

Field	Description	Example Value	Update Frequency
System ID	Unique enterprise identifier for this AI system	AI-2024-0047	At creation
System Name	Common name used within the organization	Customer Credit Scoring Model v3	At creation; update on major version change
Vendor / Source	Developer or provider of the AI system	Internal (Data Science Team) / Vendor: Equifax	At creation
Business Owner	Named individual accountable for the system's use and governance	VP Consumer Credit, Jane Smith	Update when ownership changes
Technical Owner	Named individual responsible for technical operation and maintenance	Principal Data Scientist, John Doe	Update when ownership changes
Use Case Description	Clear description of what the AI system does and in what context it is used	Scores consumer credit applicants on a 300-850 scale using 43 financial attributes to support lending decisions	Review annually
AI Type	Category of AI technology	Machine learning / supervised classification	At creation
EU AI Act Risk Tier	Classification per Section 3.1	Tier 1 — High Risk (Annex III: access to financial services)	Review when use case changes; at minimum annually
Internal Risk Rating	Enterprise risk rating from risk assessment	High	Review semi-annually for High; annually for Medium/Low
Deployment Status	Current status of the system	Production — Active	Update on status change
Deployment Date	Date first deployed to production	March 14, 2024	At creation
Last Validation Date	Date of most recent formal validation / testing	November 20, 2024	Update after each validation

Field	Description	Example Value	Update Frequency
Next Review Date	Date of next scheduled governance review	November 20, 2025	Update after each review
Data Inputs	Categories of data used by the system	Credit bureau data; bank transaction history; employment verification data	Review annually
Sensitive Data	Whether system processes regulated personal data	Yes — FCRA-regulated consumer data; GDPR personal data	Review annually
Third-Party Data Sources	External data providers	Equifax, Experian, TransUnion	Update when sources change
Regulatory Compliance Status	Compliance certification status	FCRA compliant — documented; EU AI Act high-risk — compliance in progress	Update after compliance assessments
Approval Documentation	Reference to approval records	Governance Council Approval GC-2024-031, March 12, 2024	At creation; update on re-approval
Current Issues / Flags	Open issues, audit findings, or risk flags	Monitoring: elevated false negative rate in Q1 2025 under investigation	Update as issues open/close

NOTE: The registry template above defines minimum fields. Organizations should extend the template with additional fields relevant to their regulatory environment, industry sector, and governance maturity. The registry should be maintained in a system that provides version control, access restrictions, and search capability — not a shared spreadsheet accessible to the general organization.

SECTION B — AI Risk Classification Quick Reference - Aligning Internal Classification with EU AI Act Risk Tiers

This quick reference helps managers and governance staff rapidly classify AI systems against the EU AI Act risk tier framework and the enterprise internal risk dimensions defined in Section 3.1. It should be used as the starting point for the full risk assessment process, not as a substitute for it.

Step 1: Check for Tier 0 — Prohibited Uses

If the AI system uses any of the following capabilities, it is Tier 0 PROHIBITED under EU AI Act Article 5 and must not be deployed:

⚠ PROHIBITED — Do Not Deploy AI social scoring systems that evaluate individuals based on social behavior and create differential treatment in unrelated contexts. AI that exploits vulnerabilities of specific groups (children, elderly, persons with disabilities) to distort behavior. Subliminal techniques beyond a person's consciousness to materially distort behavior in a way that causes or is likely to cause harm. Real-time remote biometric identification of individuals in publicly accessible spaces for law enforcement purposes (except in very narrow, judicially authorized contexts). Emotion recognition AI in workplace and educational settings (prohibited under EU AI Act and numerous national laws). AI systems for predictive policing of individuals based solely on profiling or personality traits without objective evidence of involvement in criminal activity.

Step 2: Check for Tier 1 — High Risk (EU AI Act Annex III)

If the AI system is used in any of the following contexts, it is Tier 1 HIGH RISK under EU AI Act Annex III and requires the full high-risk governance framework (documented risk management system, data governance, technical documentation, logging, human oversight, accuracy and robustness requirements, EU declaration of conformity, registration):

EU AI Act Annex III Category	Examples in Enterprise Context
1. Biometric identification, categorization, and emotion recognition	Facial recognition for access control; emotion detection in customer service; behavioral profiling from biometric data
2. Critical infrastructure management (energy, water, transport, internet, banking)	AI controlling power distribution; AI managing water treatment; AI directing transportation networks; AI managing core banking or payment systems
3. Educational and vocational training	AI scoring exams or assessments; AI recommending educational pathways; AI assessing student performance for advancement or qualification
4. Employment, workforce management, and access to self-employment	AI screening job applications or CVs; AI evaluating employee performance; AI making promotion recommendations; AI scheduling workers; AI monitoring employee productivity
5. Access to essential private and public services (credit, insurance, social benefits, emergency services)	AI credit scoring; AI insurance premium pricing; AI social benefit eligibility assessment; AI customer creditworthiness assessment

EU AI Act Annex III Category	Examples in Enterprise Context
6. Law enforcement (not applicable to most private enterprises)	Applies primarily to government and law enforcement agencies; limited private sector applicability
7. Migration, asylum, and border control (government agencies)	Primarily government; private sector enterprise limited applicability
8. Administration of justice, democratic processes, elections	AI in legal dispute resolution; AI analyzing legal texts to determine case outcomes

Step 3: Check for Tier 2 — Limited Risk (Transparency Obligations)

System Type	Transparency Obligation (EU AI Act Articles 50-52)
AI chatbot or virtual assistant interacting with customers or employees	Disclose to users they are interacting with an AI, not a human, at start of interaction
AI-generated text, images, audio, or video for public distribution	Label as AI-generated; deep fakes require explicit disclosure
Emotion recognition AI (where not prohibited)	Inform individuals that emotion recognition is being applied
AI-generated text published for public information	Label as AI-generated where intended to influence public opinion

Step 4: Low Risk Systems

AI systems not falling into Tiers 0, 1, or 2 are Tier 3 Low Risk under the EU AI Act and face no mandatory regulatory obligations. However, enterprise governance requires all AI systems to be registered and subject to at least basic governance oversight regardless of regulatory tier.

NOTE: Enterprise-internal risk factors may elevate the governance tier of a system above its regulatory classification. An AI system that automates internal process monitoring may be Tier 3 under the EU AI Act but warrant elevated governance treatment if it could affect employee rights, generate significant security exposure, or produce output that could affect organizational decisions. The regulatory classification is the floor, not the ceiling, of governance requirements.

SECTION C — AI Incident Response Checklist - Operational Guide for AI Incident Management

This checklist operationalizes the AI incident response process defined in Section 5.3. It is designed to be used by the AI incident responder at the time of incident, not as a policy document. It should be stored in an accessible location and reviewed annually.

Phase 1: Detection and Initial Assessment (0-1 Hour)

Action	Owner / Tool
☐ Confirm the incident: verify this is a genuine AI system failure or policy violation, not a false alarm	AI Governance Lead / monitoring system
☐ Document initial facts: AI system name, time of discovery, source of detection (monitoring alert, user report, external report), initial description of the failure	AI Incident Responder
☐ Classify initial severity: Critical / High / Medium / Low based on criteria in Section 7.3	AI Governance Lead
☐ Notify AI Governance Lead (if not already involved) and relevant Business Unit Manager	AI Incident Responder
☐ For Critical or High: notify CISO and CRO within 1 hour	AI Governance Lead
☐ Preserve evidence: capture screenshots, logs, system state without modifying any data; assign evidence custodian	Evidence Custodian (designated)

Phase 2: Containment (1-4 Hours)

Action	Owner / Tool
☐ Assess whether AI system should continue operating: is harm ongoing? Is the failure isolated or systemic?	AI Governance Lead + Business Owner
☐ If harm is ongoing or systemic: activate emergency suspension procedure; document suspension decision and time	Business Owner with CRO concurrence
☐ Notify affected business units of AI system status; provide estimated resolution timeline	Business Owner
☐ For incidents involving personal data: notify Data Protection Officer immediately; initiate GDPR breach assessment	DPO
☐ For incidents involving potential customer harm: notify Customer Relations; assess need for customer communication	Business Owner + Legal
☐ Begin identifying scope: how many users, transactions, or decisions affected?	AI Incident Responder

Phase 3: Investigation (4-48 Hours)

Action	Owner / Tool
☐ Conduct root cause analysis: document the sequence of events that led to the failure	AI Incident Responder + Technical Team
☐ Document complete impact: affected parties; decisions made; potential downstream effects	Business Owner
☐ Complete regulatory notification assessment: does this incident require notification under GDPR (72-hour clock); EU AI Act Article 73; sector-specific requirements?	Legal / Compliance
☐ Make regulatory notification decision and document; make notifications if required within required timeframes	Legal / CCO
☐ Update incident record with all investigation findings	AI Incident Responder
☐ Brief governance council if Critical or High severity	AI Governance Lead

Phase 4: Remediation (Days 2-30)

Action	Owner / Tool
☐ Implement corrective controls; document all changes	Technical Team + Business Owner
☐ Re-validate AI system if the incident involved a fundamental model or system failure	AI Governance Lead + Technical Team
☐ Update AI Risk Register with incident details and new/modified controls	AI Governance Lead
☐ Notify affected parties if required by regulation or privacy obligation	Legal / Customer Relations
☐ Return AI system to operation if suspended; document re-activation decision with sign-off	Business Owner + AI Governance Lead

Phase 5: Post-Incident Review (30-60 Days)

Action	Owner / Tool
☐ Complete Post-Incident Report: timeline, root cause, impact, regulatory notifications, remediation actions	AI Incident Responder
☐ Governance council Post-Incident Briefing: lessons learned; governance gaps identified	AI Governance Lead

Action	Owner / Tool
☐ Update AI governance program based on lessons learned: policies, controls, monitoring thresholds	AI Governance Lead
☐ Internal audit notification: share Post-Incident Report with CAE for inclusion in audit universe	AI Governance Lead
☐ Board reporting: include in next Quarterly AI Risk Report with appropriate detail	AI Governance Lead

NOTE: Regulatory notification timelines are the most time-critical elements of incident response. GDPR Article 33 requires supervisory authority notification within 72 hours of becoming aware of a personal data breach — not 72 hours after investigation is complete. EU AI Act Article 73 requires providers of high-risk AI systems to notify the relevant national authority of serious incidents 'without undue delay.' Document when you became aware of the incident, not when you confirmed all details.

SECTION D — Vendor AI Risk Assessment Questionnaire - -Third-Party AI Governance Due Diligence

This questionnaire should be completed by all third-party AI system vendors before procurement approval. Responses should be evaluated by the governance function against the enterprise's risk tolerance. Vendors who cannot or will not complete this questionnaire should not be approved for high-risk AI deployments.

Section D.1: AI Governance Program

Question	Guidance on Expected Response
Does the vendor have a documented AI governance policy? (Provide copy)	Expect: Published or shareable written policy covering acceptable use, risk management, and ethical AI commitments
Does the vendor maintain an AI risk management program? What framework does it align with (NIST AI RMF, ISO 42001, EU AI Act)?	Expect: Named framework; description of risk assessment process; description of risk management governance structure
Has the vendor obtained any third-party AI governance certifications? (ISO 42001, SOC 2 with AI controls, sector-specific certifications)	Expect: Certification with scope and certification body; date of last audit
Does the vendor conduct regular independent assessments of its AI governance program?	Expect: Frequency; scope; most recent assessment summary or attestation

Section D.2: AI Model Documentation and Validation

Question	Guidance on Expected Response
Can the vendor provide documentation of the AI model being procured, including: model type; training data description; validation methodology; known limitations?	Expect: Model card or equivalent documentation; validation report or summary; clear statement of known limitations and failure modes
Has the AI model been tested for bias against protected class characteristics? What were the results?	Expect: Description of bias testing methodology; summary of results; description of any bias mitigations applied
What accuracy and performance metrics has the model been validated against? What are the validated thresholds?	Expect: Specific performance metrics; holdout test results; out-of-time validation results where applicable
Has the model been tested for robustness against adversarial inputs and edge cases?	Expect: Description of adversarial testing; edge case testing results; known edge cases with documented behavior

Section D.3: Data Governance and Privacy

Question	Guidance on Expected Response
Does the vendor use customer data to train or improve the AI model? Can this be contractually prohibited?	Expect: Clear statement of data use for training; confirmation that contractual prohibition is available; standard Data Processing Agreement terms
What personal data does the vendor's AI system process? What legal basis is claimed under GDPR?	Expect: Complete list of personal data categories; specific GDPR legal basis for each processing purpose; DPA available for execution
Where is data processed geographically? Are any transfers outside the EEA, UK, or other regulated jurisdictions involved?	Expect: Complete data processing location disclosure; description of transfer mechanisms for any cross-border transfers (SCCs, adequacy decisions)
What data retention periods apply to data processed by the AI system?	Expect: Specific retention periods by data category; description of secure deletion process

Section D.4: Security and Access Controls

Question	Guidance on Expected Response
What security certifications does the vendor hold for systems hosting or processing enterprise data? (ISO 27001, SOC 2 Type II, etc.)	Expect: Current certification with scope; most recent audit report available under NDA
What controls does the vendor implement against prompt injection attacks?	Expect: Description of prompt injection mitigation controls; results of penetration testing
What audit logging capabilities does the vendor provide for the enterprise's use of the AI system?	Expect: Description of available logs; retention period; access mechanism; SIEM integration capability
What is the vendor's security incident notification procedure and timeline?	Expect: Written incident response SLA; notification timeline; description of communication process

Section D.5: EU AI Act and Regulatory Compliance

Question	Guidance on Expected Response
What is the vendor's assessment of the AI system's EU AI Act risk tier? (If different from enterprise assessment, explain why)	Expect: Written risk classification with justification; reference to specific Annex III categories if applicable
For high-risk AI systems: Has the vendor completed or is the vendor preparing a EU declaration of conformity and CE marking? Expected completion date?	Expect: Status update; timeline; description of compliance approach

Question	Guidance on Expected Response
How does the vendor address human oversight requirements? What mechanisms does the system provide for human review, intervention, and override?	Expect: Technical description of human oversight mechanisms; documentation of how oversight is designed into the system
Has the vendor registered or does the vendor plan to register the AI system in the EU AI Act database for high-risk systems?	Expect: Registration status; timeline for compliance with registration requirements

NOTE: This questionnaire reflects requirements current as of March 2026. It should be reviewed and updated when significant regulatory changes occur — in particular, when EU AI Act implementation guidance is published for high-risk AI system compliance (expected 2026) and when EU harmonized standards for the AI Act are finalized. Organizations should work with legal counsel to incorporate questionnaire responses into vendor contracts as representations and warranties.

Section D.6: AI Vendor Contract Clause Checklist

The following contract clauses should be included in all agreements with AI vendors providing Tier 1 or Tier 2 AI systems. Legal counsel must review and adapt language for each specific vendor relationship, jurisdiction, and system type. Absence of a required clause in a proposed vendor contract should be treated as a governance risk requiring escalation before execution.

Contract Clause	Required	Minimum Requirement
Data usage restrictions	Required	Prohibition on vendor using enterprise data (including prompt inputs and outputs) to train, fine-tune, or improve AI models without explicit written consent. Must specify permitted and prohibited data uses.
IP ownership of AI outputs	Required	Clear allocation of intellectual property rights in AI-generated outputs produced using enterprise data or prompts. Enterprise must own or hold perpetual license to outputs generated on its behalf.
Model retraining notification	Required	Vendor must provide advance written notice (minimum 30 days) of material changes to underlying AI model, including retraining events that could alter model behavior, accuracy, or output characteristics.
Incident notification SLA	Required	Vendor must notify enterprise of security incidents, data breaches, or AI system failures affecting enterprise data or systems within 24 hours of discovery; must provide root cause analysis within 72 hours.
Audit rights	Required	Enterprise right to audit vendor AI governance program, including right to request evidence of bias testing results, validation documentation, and security controls; minimum annual audit right; vendor must cooperate with regulatory inspections.

Contract Clause	Required	Minimum Requirement
Subprocessor disclosure	Required	Vendor must disclose all subprocessors with access to enterprise data; must obtain enterprise consent before engaging new subprocessors for AI processing; must flow down equivalent data protection obligations.
Training data provenance	Required for Tier 1	Vendor must provide documentation of training data sources, collection methods, licensing status, and known limitations; must disclose any personal data used in training and the legal basis for its use.
Termination and data return	Required	On termination, vendor must (a) return all enterprise data in a portable format within 30 days; (b) certify deletion of all copies of enterprise data from vendor systems; (c) certify deletion from AI training datasets where applicable.
Exit provisions	Required	Vendor must provide transition assistance for minimum 90 days post-termination; must provide documentation sufficient for enterprise to migrate to an alternative system; must not degrade service quality during notice period.
Regulatory compliance warranties	Required	Vendor warrants that AI system complies with applicable regulations (EU AI Act, GDPR, sector-specific requirements) as of contract date; obligation to notify enterprise of any regulatory non-compliance within 5 business days.
Human oversight mechanisms	Required for Tier 1	Vendor must maintain and document human oversight mechanisms required by EU AI Act Article 14 for high-risk systems; must provide evidence of testing of override mechanisms on request.
Model update governance	Recommended	Vendor must provide release notes for all model updates; enterprise retains right to delay model updates for a defined period (e.g., 30 days) to allow internal validation before automatic upgrade.

SECTION E — Quarterly AI Risk Dashboard - Board-Level Reporting Template

This dashboard template operationalizes the quarterly board reporting requirements from Section 8.1. It is designed to provide the board risk committee with a consistent, standardized view of AI risk that enables trend analysis across reporting periods.

E.1 AI Portfolio Summary

Metric	Current Quarter	Prior Quarter	Change
Total Active AI Systems	[Number]	[Number]	[+/-]
Tier 0 (Prohibited) Systems	Should always be zero	Should always be zero	N/A
Tier 1 (High Risk) Systems	[Number]	[Number]	[+/-]
Tier 2 (Medium Risk) Systems	[Number]	[Number]	[+/-]
Tier 3 (Low Risk) Systems	[Number]	[Number]	[+/-]
New Deployments This Quarter	[Number]	[Number]	N/A
Systems Retired/Suspended This Quarter	[Number]	[Number]	N/A
Systems with Open Risk Findings (High or Critical)	[Number]	[Number]	[+/-]

E.2 Incident Summary

Incident Metric	Current Quarter	Prior Quarter	YTD Total
Total Incidents	[Number]	[Number]	[Number]
Critical Incidents	[Number]	[Number]	[Number]
High Incidents	[Number]	[Number]	[Number]
Medium Incidents	[Number]	[Number]	[Number]
Regulatory Notifications Made	[Number]	[Number]	[Number]
Mean Time to Detection (Critical/High) — hours	[Number]	[Number]	N/A
Open Incidents (not yet fully remediated)	[Number]	[Number]	N/A

E.3 Governance Program Health

Governance Metric	Current Status	Target
AI Systems Registry completeness	[% of known AI systems registered]	100%
High-risk AI system documentation completeness	[% of Tier 1 systems with complete documentation]	100%
Employee AI training completion	[% of employees with AI interaction who have completed required training]	100%
AI audit findings — open Critical	[Number]	Zero
AI audit findings — open High past due	[Number]	Zero
Third-party AI vendor assessments current	[% of Tier 1/2 vendors with current assessment]	100%
Monitoring KPIs reported this quarter	[% of required monitoring metrics with current data]	100%
Governance council meetings held (vs. scheduled)	[Number held / Number scheduled]	100%

E.4 Regulatory Status

Regulatory Requirement	Compliance Status
EU AI Act — Prohibited practices compliance (from February 2025)	[Compliant / In progress / Not started — with brief description]
EU AI Act — GPAI model obligations (from August 2025)	[Applicable / Not applicable — if applicable: Compliant / In progress / Not started]
EU AI Act — High-risk AI system obligations (August 2026 deadline)	[Number of high-risk systems; documentation completeness; overall readiness assessment]
EU AI Act — AI literacy obligations (from February 2025)	[Training completion rate; training program currency]
GDPR — AI processing compliance	[Status of DPIAs for AI systems processing personal data; any enforcement matters]
Sector-specific regulatory requirements (OCC, FDA, FCA, etc. — as applicable)	[Status by applicable regulator]
ISO 42001 — Certification status (if pursued)	[Certified / Pursuing / Not pursuing — with target date if applicable]

E.5 Emerging Risks and Trends

This section provides the board with forward-looking AI risk intelligence. It should include: significant AI incidents at peer organizations with applicability to the enterprise; material regulatory developments and their anticipated compliance implications; emerging AI capability developments with governance implications; and the board-level assessment of AI risk trajectory (improving / stable / deteriorating) with supporting rationale.

NOTE: *This dashboard template represents the minimum required content for board AI risk reporting. Organizations in heavily regulated sectors (financial services, healthcare, critical infrastructure) should supplement with sector-specific metrics. The dashboard should be presented consistently across quarters to enable trend analysis; format changes should only be made with governance council approval to maintain comparability.*

SECTION F — AI Governance Regulatory Reference - Key Standards and Regulatory Frameworks

This appendix provides a structured reference to the principal regulatory frameworks and standards that govern enterprise AI. It is designed for use by managers and governance staff who need to understand the regulatory landscape without requiring a legal background.

F.1 NIST AI Risk Management Framework (AI RMF 1.0)

Reference	Detail
Full Title	NIST AI 100-1: Artificial Intelligence Risk Management Framework (AI RMF 1.0)
Publisher	National Institute of Standards and Technology, U.S. Department of Commerce
Date	January 26, 2023; Generative AI Profile (NIST AI 600-1) published July 26, 2024
Legal Status	Voluntary guidance (U.S.); incorporated by reference into U.S. federal agency AI guidance and Executive Order 14110 (2023)
Core Functions	GOVERN, MAP, MEASURE, MANAGE — structured lifecycle approach to AI risk management
Key Governance Requirement	GOVERN function requires organizational policies, accountability structures, risk tolerance documentation, and senior leadership engagement in AI risk management
Access	Free: nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf

F.2 EU Artificial Intelligence Act

Reference	Detail
Full Title	Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)
Publisher	European Parliament and Council of the European Union
Date	Entered into force August 1, 2024; phased implementation 2025-2027
Legal Status	Binding EU Regulation; extraterritorial effect (applies to providers and deployers placing AI on EU market or affecting EU persons)
Key Prohibitions	Article 5: real-time biometric surveillance, social scoring, subliminal manipulation, exploitation of vulnerabilities
High-Risk Obligations	Articles 9-15: risk management system, data governance, technical documentation, logging, human oversight, accuracy, cybersecurity
Fines	Prohibited practices: €35 million or 7% of global turnover. High-risk non-compliance: €15 million or 3%. Other: €7.5 million or 1.5%
Key Deadlines	Feb 2025: prohibitions + AI literacy. Aug 2025: governance + GPAI obligations. Aug 2026: high-risk AI obligations. Aug 2027: regulated product AI

Reference	Detail
Access	EUR-Lex: eur-lex.europa.eu — search Regulation 2024/1689

F.3 ISO/IEC 42001:2023 — AI Management System Standard

Reference	Detail
Full Title	ISO/IEC 42001:2023 — Information Technology — Artificial Intelligence — Management Systems
Publisher	International Organization for Standardization (ISO) / International Electrotechnical Commission (IEC)
Date	Published December 2023
Legal Status	Voluntary international standard; certifiable by accredited certification bodies; increasingly referenced in procurement requirements
Structure	Based on ISO High Level Structure (same as ISO 9001, ISO 27001); 10 clauses + Annex A (AI management controls)
Key Requirement	Establishes, implements, maintains, and continually improves an AI Management System (AIMS) using Plan-Do-Check-Act methodology
Annex A Controls	Controls for AI lifecycle governance, risk assessment, data governance, third-party oversight, transparency, bias management, and human oversight
Certification	Three-year certification with annual surveillance audits; issued by accredited certification bodies
Access	iso.org/standard/42001 — full text available for purchase; preview available free

F.4 OECD AI Principles

Reference	Detail
Full Title	OECD Principles on Artificial Intelligence
Publisher	Organisation for Economic Co-operation and Development
Date	First adopted 2019; updated 2024
Legal Status	Non-binding; endorsed by all OECD and G20 nations; foundational to EU AI Act, NIST AI RMF, and most national AI strategies
Five Principles	1. Inclusive growth, sustainable development, and well-being. 2. Human-centred values and fairness. 3. Transparency and explainability. 4. Robustness, security, and safety. 5. Accountability
Governance Implication	Provides the ethical framework that the binding regulations (EU AI Act) and voluntary frameworks (NIST AI RMF, ISO 42001) operationalize; organizations demonstrating adherence to OECD principles are better positioned for compliance across all jurisdictions
Access	oecd.ai/en/ai-principles — free access

F.5 Key Sector-Specific Frameworks

Sector	Regulatory Authority and Guidance	Key AI Governance Implication
Financial Services (U.S.)	OCC Bulletin 2011-12 (Model Risk Management); extended to AI and ML models by 2021 Supervisory Guidance SR 11-7; Federal Reserve, OCC, FDIC joint guidance on use of AI in financial services (2021)	AI credit models, pricing models, and risk models in banks must meet MRM standards: documentation, independent validation, ongoing monitoring, governance oversight
Financial Services (EU)	EBA Guidelines on Internal Governance; ECB Supervisory Expectations on AI; ESMA guidance on algorithmic trading	High-risk AI in credit decisions subject to EU AI Act obligations plus sector-specific MRM requirements; transparency obligations for automated credit decisions under GDPR Recital 71
Healthcare (U.S.)	FDA Software as a Medical Device (SaMD) Guidance; FDA AI/ML Action Plan (2021)	AI in medical devices and clinical decision support subject to FDA oversight; clinical AI subject to HIPAA data governance requirements; AI diagnostic tools classified as medical devices requiring 510(k) clearance or PMA approval
Healthcare (EU)	EU MDR (Medical Device Regulation 2017/745); IVDR; EU AI Act high-risk classification for AI in medical devices	AI medical devices embedded in regulated products: EU AI Act compliance from August 2027; MDR CE marking still required; Technical File documentation required for both frameworks
Insurance	IAIS Application Paper on AI in Insurance (2023); state-level insurance regulation (U.S.); Solvency II (EU)	AI pricing and underwriting models: fairness requirements; actuarial certification standards; state insurance regulator AI guidance (Colorado, New York NAIC Model Bulletin 2023)
Human Resources / Employment	EEOC Guidance on AI in Employment (2023); New York City Local Law 144 (2023) AI hiring tool audit requirements; NIST SP 1270 AI bias guide	AI hiring tools: algorithmic bias audit required annually in New York City and other jurisdictions; EEOC enforcement for Title VII violations via AI; EU AI Act Annex III high-risk classification for employment AI

SECTION G — Phased Implementation Roadmap - Building an Enterprise AI Governance Program from Foundation to Maturity

This roadmap provides a phased implementation plan for organizations building an AI governance program from scratch or formalizing an existing informal one. It is calibrated to the governance requirements in Sections 1–9 and the maturity model in Section 9.1. Timelines assume dedicated governance resources; organizations with limited resources should extend timelines proportionally. For organizations without dedicated compliance, legal, or AI governance staff, the companion volume *AI for Small Business* provides simplified implementation guidance calibrated to smaller-scale operations.

Phase 1: Foundation (Days 1–30) — Target: Maturity Level 1 → Level 2 Entry

Milestone	Deliverable	Handbook Reference
Designate AI Governance Lead	Named individual with authority and time allocation	Section 1.1
Complete AI systems inventory	Draft AI Systems Registry covering all known AI systems	Section A
Publish interim AI Acceptable Use Policy	Board- or executive-approved policy document	Section 2.1
Classify top 10 AI systems by risk tier	Risk classification per EU AI Act framework	Section 3.1; Section B
Identify AI literacy training status	Gap assessment against Article 4 obligation	Section 2.1 (Training Matrix)
Designate AI incident responder	Named individual; distribute incident checklist	Section C
Review top 3 AI vendor contracts	Gap assessment against contract clause checklist	Section D.6

Phase 2: Baseline Governance (Days 31–90) — Target: Maturity Level 2

Milestone	Deliverable	Handbook Reference
Establish AI Governance Council	Charter, composition, meeting schedule	Section 1.1
Complete risk classification for all registered AI systems	Risk tier assigned to every registry entry	Section 3.1
Implement AI use approval process	Documented approval workflow	Section 2.2
Complete risk assessments for all Tier 1 (High Risk) systems	Documented risk assessment per system	Section 3.2–3.3
Launch AI literacy training program	Role-appropriate training per EU AI Act Article 4	Section 2.1 (Training Matrix)
Establish AI monitoring for Tier 1 systems	Monitoring metrics defined and collection initiated	Section 5.1
Complete full AI vendor assessment for Tier 1 vendors	Vendor questionnaire completed and evaluated	Section D

Phase 3: Defined Program (Days 91–180) — Target: Maturity Level 3 Entry

Milestone	Deliverable	Handbook Reference
Comprehensive policy framework	All five policy domains documented and approved	Section 2.1
Decision rights framework	Documented authority matrix with escalation paths	Section 1.2
Control framework for all risk tiers	Controls implemented and documented	Section 4
Prompt governance program (if using GenAI)	Prompt classification, sensitive data controls, system prompt registry	Section 6
Quarterly board AI risk report — first edition	Dashboard template populated with actual data	Section 8.1; Section E
Internal audit — first AI governance assessment	Audit report with findings and recommendations	Section 7
Shadow AI detection and remediation program	Discovery exercise completed; unregistered tools addressed	Section 2.2

Phase 4: Managed Program (Days 181–365) — Target: Maturity Level 3

Milestone	Deliverable	Handbook Reference
Full AI risk register operational	All AI systems with documented risk assessments, treatment plans, and named owners	Section 3.3
Quantitative governance KPIs	Board KPIs with baseline data and trend analysis	Section 8.1 (KPI Definitions)
Third-party AI risk program	All Tier 1 and Tier 2 vendors assessed; contract protections confirmed	Section D
Incident management tested	Tabletop exercise completed; response procedures validated	Section 5.3; Section C
Annual governance review	Maturity assessment completed; improvement plan for Year 2 approved	Section 9
ERM integration confirmed	AI risk integrated into enterprise risk management reporting	Section 1.3
Second quarterly board report delivered	Board feedback incorporated; reporting format stabilized	Section 8.1

Scaling Note for Mid-Market and Smaller Organizations. Organizations without dedicated CRO, CCO, CISO, and CDO functions can consolidate governance roles. The critical requirement is *separation of duties between those who deploy AI systems and those who assess their risk*. A mid-market organization may assign governance council responsibilities to an existing risk committee with AI added to its charter. For organizations with fewer than 50 employees or limited AI deployments, the companion volume *AI for Small Business: Scaling the Enterprise AI Handbook to Solo and Micro-Team Operators* provides governance checklists and simplified frameworks designed for this context. The *Enterprise AI Systems — Organizational Maturity Analysis* companion volume provides workforce planning and cost modeling to help mid-market organizations budget governance program implementation realistically.

REFERENCES

All sources cited in this handbook are documented below. Where the primary source was not directly accessed, this is noted. Regulatory documents and international standards are cited to official publication sources.

Primary Regulatory and Standards Sources

European Parliament and Council of the European Union. (2024). Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). Official Journal of the European Union, L 2024/1689, June 13, 2024. Available at eur-lex.europa.eu.

National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0) (NIST AI 100-1). U.S. Department of Commerce. Published January 26, 2023. Available at nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf.

National Institute of Standards and Technology. (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1). U.S. Department of Commerce. Published July 26, 2024. Available at nist.gov.

International Organization for Standardization. (2023). ISO/IEC 42001:2023 — Information Technology — Artificial Intelligence — Management Systems. Published December 2023. Available for purchase at iso.org/standard/42001.

Organisation for Economic Co-operation and Development. (2024). OECD Principles on Artificial Intelligence (updated). OECD. Available at oecd.ai/en/ai-principles.

Committee of Sponsoring Organizations of the Treadway Commission (COSO). (2017). Enterprise Risk Management — Integrating with Strategy and Performance. COSO. Available at coso.org.

Government and Regulatory Guidance

European Commission. (n.d.). High-level summary of the EU AI Act. Artificial Intelligence Act website. Available at artificialintelligenceact.eu/high-level-summary.

European Commission. (2024). EU AI Act Explanatory Memorandum. European Commission Digital Strategy. Available at digital-strategy.ec.europa.eu.

Federal Reserve, OCC, and FDIC. (2021). Request for Information and Comment on Financial Institutions' Use of Artificial Intelligence, including Machine Learning. Joint Supervisory Guidance.

NHS England. (2023). AI Governance Framework for Clinical AI. NHS England / NHS AI Lab. Available at england.nhs.uk.

Office of the Comptroller of the Currency. (2011). OCC Bulletin 2011-12: Sound Practices for Model Risk Management. U.S. Department of the Treasury.

UK Financial Conduct Authority. (2022). Feedback Statement on AI and Machine Learning. FCA. Available at fca.org.uk.

U.S. Equal Employment Opportunity Commission. (2023). The Americans with Disabilities Act and the Use of Software, Algorithms, and Artificial Intelligence to Assess Job Applicants and Employees. EEOC Technical Assistance Document, May 12, 2023.

U.S. Executive Office of the President. (2023). Executive Order 14110: Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence. Federal Register, October 30, 2023.

Technology Company Documents (Cited as Industry Examples)

Amazon Web Services. (n.d.). ISO 42001 AI Management System. AWS Compliance Documentation. Available at aws.amazon.com/compliance/iso-42001-faqs.

Apple Inc. (2024). Private Cloud Compute: A new frontier for AI privacy in the cloud. Apple WWDC 2024 Technical Documentation. Available at security.apple.com.

Google DeepMind. (2024). Frontier Safety Framework. Published May 2024. Available at deepmind.google/safety.

Google LLC. (2024). ISO/IEC 42001:2023 Compliance. Google Cloud Documentation. Available at cloud.google.com/security/compliance/iso-42001.

Google. (2018). Artificial Intelligence at Google: Our Principles. Published June 2018. Available at ai.google/principles.

JPMorgan Chase & Co. (2024). 2024 Annual Report to Shareholders. Available at jpmorganchase.com.

Microsoft Corporation. (2022). Microsoft Responsible AI Standard, Version 2. Published June 2022. Available at microsoft.com/en-us/ai/responsible-ai.

Microsoft Corporation. (2024). Responsible AI Transparency Report 2024. Available at microsoft.com/en-us/ai/responsible-ai-transparency-report.

Microsoft Corporation. (2024). ISO/IEC 42001:2023 Compliance. Microsoft Learn Compliance Documentation. Available at learn.microsoft.com/en-us/compliance/regulatory/offering-iso-42001.

Academic and Practitioner Research

Bujno, M., Davine, C., & Abrash, L. (Deloitte LLP). (2025, April 24). Strategic Governance of AI: A Roadmap for the Future. Harvard Law School Forum on Corporate Governance. Available at corpgov.law.harvard.edu.

CIO Magazine / Foundry. (2025). 2025 State of the CIO Survey. IDG / Foundry. Available at cio.com.

Cloud Security Alliance AI Safety Initiative. (2026, March 13). EU AI Act High-Risk Compliance Deadline: Enterprise Readiness Gap. CSA Research Note. Available at labs.cloudsecurityalliance.org.

Gaube, S., et al. (2023). The impact of AI suggestions on radiologists' decisions: a pilot study of explainability and attitudinal priming interventions in mammography examination. Scientific Reports, 13, 8592. DOI: 10.1038/s41598-023-36435-3.

Gartner. (2024). Gartner Predicts That Over 60% of Enterprises Will Require Formal AI Governance Frameworks by 2026. Gartner Research. Available at gartner.com.

Goldman Sachs Group. (2023). 2023 Annual Report. Model Risk Management Disclosures. Available at goldmansachs.com.

Institute of Internal Auditors. (2024). Global Internal Audit Standards. IIA. Available at theiia.org.

KPMG Switzerland. (2025). ISO/IEC 42001: A new standard for AI governance. KPMG Insights. Available at kpmg.com/ch.

Liminal AI. (2025). Enterprise AI Governance: Complete Implementation Guide (2025). Liminal. Available at liminal.ai.

OWASP. (2025). OWASP Top 10 for Large Language Model Applications, Version 2025. Open Web Application Security Project. Available at owasp.org.

Standard Chartered PLC. (2023). 2023 Annual Report. Model Risk and AI disclosures. Available at sc.com.

Legal Records Cited

Moffatt v. Air Canada, 2024 BCCRT 149. British Columbia Civil Resolution Tribunal, February 14, 2024. [Corporate liability for AI chatbot misinformation]

News and Trade Press Sources

Bloomberg. (2023, April 2). Samsung Bans Employee Use of AI Tools Like ChatGPT After Sensitive Data Leak. Bloomberg Technology.

Reuters. (2018, October 10). Amazon scraps secret AI recruiting tool that showed bias against women. Reuters Technology.

The Verge. (2023, April 2). Samsung workers made a major error by using ChatGPT. The Verge.

Wall Street Journal. (2023, May 19). Apple Restricts ChatGPT Use Among Employees Over Confidentiality Concerns. WSJ Technology.

GLOSSARY OF TERMS

This glossary defines technical, regulatory, and governance terms used throughout this handbook. Core definitions for AI System, High-Risk AI System, General-Purpose AI Model, AI Provider, AI Deployer, AI Model vs. AI Use Case, and Agentic AI System appear in the Key Definitions section of the Executive Introduction. This glossary supplements those definitions with additional terms used in the operational sections and appendices.

Term	Definition
Acceptable Use Policy (AUP)	A documented organizational policy defining permitted and prohibited uses of AI systems by employees, contractors, and third parties operating under the organization's authority.
Adversarial Attack	A deliberate attempt to cause an AI system to produce incorrect outputs by manipulating its inputs, training data, or operating environment. Includes prompt injection, data poisoning, model extraction, and evasion attacks.
AI Governance Council	The senior cross-functional body responsible for strategic oversight, policy approval, risk tolerance setting, and escalated risk adjudication for all AI systems within the enterprise. See Section 1.1.
AI Literacy	The skills, knowledge, and understanding necessary for an individual to make informed decisions regarding the deployment and risks of AI systems and to understand the potential harms AI can cause. Required by EU AI Act Article 4.
AI Management System (AIMS)	A set of interrelated organizational elements — policies, objectives, processes, and resources — intended to establish and maintain responsible development, provision, or use of AI systems. Defined by ISO/IEC 42001:2023.
AI Systems Registry	The enterprise's authoritative inventory of all AI systems in use, development, or procurement. See Section A for the registry template.
Automation Bias	The tendency of human reviewers to defer to AI system recommendations without exercising independent judgment, even when the AI output is incorrect. See Section 5.2.
Bias (AI)	Systematic and unfair differences in AI system outputs that disadvantage individuals or groups based on protected characteristics (race, gender, age, disability, national origin) without legitimate basis.
CE Marking	The conformity marking required under EU product safety legislation indicating that a product meets EU requirements. Required for high-risk AI systems under the EU AI Act.
COSO ERM	Committee of Sponsoring Organizations of the Treadway Commission Enterprise Risk Management Framework (2017). The foundational enterprise risk management framework referenced in Section 1.3.
Data Loss Prevention (DLP)	Technical controls that detect and prevent the unauthorized transmission of sensitive data outside the organization's security perimeter, including through AI system interfaces.
Data Processing Agreement (DPA)	A contract between a data controller and data processor required under GDPR Article 28, specifying the terms of personal data processing. Required for AI vendors processing personal data.

Term	Definition
Data Protection Impact Assessment (DPIA)	A documented assessment of the impact of data processing operations on the protection of personal data, required under GDPR Article 35 for processing likely to result in a high risk to individuals' rights.
Decision Rights	Documented authorities defining who may approve, modify, pause, or terminate an AI system at each stage of its lifecycle. See Section 1.2.
Deployer	Under the EU AI Act (Article 3(4)), a natural or legal person that uses an AI system under its own authority, except for personal non-professional use. Most enterprises are Deployers.
Disparate Impact	A legal and statistical concept describing when a facially neutral practice (including AI system outputs) disproportionately affects a protected group. The standard measure for AI bias in employment and credit contexts.
Enterprise Risk Management (ERM)	The organization-wide framework for identifying, assessing, managing, and monitoring risks across all business functions. AI risk management should be integrated into ERM per NIST AI RMF guidance.
Explainability	The degree to which an AI system's decision logic can be understood by humans, particularly by affected parties and oversight functions. Related terms: interpretability, transparency.
Fine-Tuning	The process of further training a pre-trained AI model on a specific dataset to adapt it for a particular use case or domain. Creates additional data governance obligations.
Fundamental Rights Impact Assessment (FRIA)	Required under EU AI Act Article 27 for deployers of high-risk AI systems in certain categories. Assesses the impact of the AI system on the fundamental rights of affected individuals.
Hallucination	An AI system output that is factually incorrect, fabricated, or unsupported by the system's training data or knowledge base, but presented with apparent confidence. A primary risk category for generative AI.
Human-in-Command	The highest level of human oversight, where a human makes the final decision and the AI serves in an advisory role only. Required for the highest-risk AI decisions.
Human-in-the-Loop (HITL)	A level of human oversight where a human actively reviews AI output before a decision is recorded. The AI provides a recommendation; the human decides.
ISO/IEC 42001:2023	The international standard specifying requirements for an AI Management System (AIMS). The first international AI-specific management system standard, published December 2023.
Key Risk Indicator (KRI)	A metric that provides early warning of increasing risk exposure. Used in AI monitoring programs to detect performance degradation, bias drift, or control failures.
LIME	Local Interpretable Model-agnostic Explanations. A technique for generating human-interpretable explanations of individual AI model predictions.

Term	Definition
Model Card	A standardized document describing an AI model's purpose, training data, performance characteristics, limitations, and intended use. Originally proposed by Mitchell et al. (2019).
Model Drift	The degradation of AI model performance over time due to changes in the data distribution, operating environment, or relationship between input features and outcomes.
Model Risk Management (MRM)	The discipline of managing risks arising from the use of quantitative models in business decisions. Governed by OCC Bulletin 2011-12 in banking; extended to AI models.
Multi-Model Orchestration	An AI architecture in which outputs from one model serve as inputs to another, creating a chain of AI processing. Requires end-to-end governance across the full chain. See Section 3.4.
NIST AI RMF	National Institute of Standards and Technology Artificial Intelligence Risk Management Framework, Version 1.0 (January 2023). The leading U.S. voluntary framework for AI risk management.
NIST AI 600-1	NIST Generative AI Profile (July 2024). Supplementary guidance extending the NIST AI RMF to address risks specific to generative AI systems.
OWASP LLM Top 10	Open Web Application Security Project Top 10 for Large Language Model Applications. Identifies the ten most critical security risks for enterprise LLM deployments, updated 2025.
Population Stability Index (PSI)	A statistical metric measuring how much a variable's distribution has changed between two time periods. Used in AI monitoring to detect data drift (PSI > 0.25 indicates significant drift).
Prompt Injection	An attack technique in which a user crafts an input (prompt) designed to override or bypass the AI system's intended instructions, constraints, or safety controls. Ranked LLM01 in OWASP LLM Top 10 (2025).
Provider	Under the EU AI Act (Article 3(3)), an entity that develops an AI system or has one developed and places it on the market or puts it into service under its own name or trademark. Carries the most extensive compliance obligations.
RACI Matrix	A responsibility assignment framework: Responsible (does the work), Accountable (owns the outcome), Consulted (provides input), Informed (receives updates). See Section 1.1.
Retrieval-Augmented Generation (RAG)	An AI architecture in which a generative model retrieves information from external data sources to augment its responses. Introduces data source governance requirements. See Section 3.4.
Residual Risk	The risk remaining after current controls have been applied. Documented in the AI Risk Register. See Section 3.3.
Shadow AI	AI tools and systems used by employees without formal organizational approval, registration, or governance oversight. A primary source of data leakage risk.

Term	Definition
SHAP	SHapley Additive exPlanations. A game-theory-based technique for explaining individual AI model predictions by computing the contribution of each feature to the output.
System Prompt	Pre-configured instructions embedded in a generative AI deployment that define the AI's behavior, persona, scope, and constraints. Subject to version control and change management. See Section 6.
TEVV	Testing, Evaluation, Verification, and Validation. The NIST AI RMF methodology for assessing AI system performance, safety, and fitness for purpose before and during deployment.
Three Lines of Defense	A governance model distinguishing first-line operational ownership, second-line risk oversight, and third-line independent assurance. Applied to AI governance in Section 7.1a.

Document Revision History

v1.0 — May 2026. Pre-deposit editorial sprint applied. Source verification campaign completed (Passes 1–34). Volume manuscript ready for Zenodo CC BY-NC 4.0 deposit.

— END OF ENTERPRISE AI GOVERNANCE HANDBOOK —

Version 1.0 — May 2026 — Corporate Edition | Research current to March 2026 | Review and update annually or upon material regulatory change

About the Series

The binding constraint on enterprise AI is no longer the technology — it is leadership, governance, organizational readiness, and workforce capability.

This volume is one part of the **Enterprise AI Handbook Series**, a coordinated set of thirteen volumes covering enterprise AI strategy, governance, organizational readiness, systems development, and everyday use. Each volume stands on its own for its intended reader, yet all share a common analytical framework, consistent terminology, and the same epistemic labeling of every claim — so guidance carries across roles instead of fragmenting between them.

Use the table below in two ways: to **go deeper** on a topic adjacent to this volume, or to **point a colleague** to the volume written for their role. The series is designed so an executive, a manager, a technical practitioner, and a frontline user can each enter at the right level and still be working from the same playbook.

#	Volume	Intended Reader	What It Delivers
CORE SERIES — Volumes 1–10			
1	Strategic Opportunity & Risk Analysis	C-suite, strategists, board members	Makes the executive case for acting on AI now — mapping the global adoption landscape, the strategic opportunities, and the risks of moving too fast or not at all.
2	Enterprise AI Governance Handbook	General managers, CROs, CCOs, legal counsel, board members	An operational governance framework — policy, risk classification, Three Lines of Defense, RACI, vendor clauses, and board KPIs — mapped to NIST, the EU AI Act, ISO 42001, and the OECD Principles.
3	Manager's Handbook: Thriving with Rapid AI Adoption	Managers, team leaders, senior executives	A research-grounded field guide for leading teams through rapid AI adoption, with per-chapter action summaries, risk warnings, and 30-60-90 day plans.
4	AI Organizational Maturity Analysis	CTOs, CIOs, AI program leaders, budget owners	Locates an organization on a five-level AI maturity model and details the staffing, cost, and risk profile of each level across four organization types.
5	AI Maturity-Based Personnel, Tooling, and Cost Analysis	AI program managers, CFOs, HR leaders, procurement	Puts hard numbers to AI capability — the people, tools, and annual budget required at each maturity level, and the investment needed to advance.
6	AI Personnel & Tooling Handbook	CAIOs, AI hiring managers, procurement, org designers	Model org structures, role specifications, tooling, and separation-of-duties controls for staffing and equipping a Level 4 (Managed) enterprise AI program.
7	Enterprise AI Systems Development Handbook	Technical practitioners, managers, architects, security engineers	The comprehensive technical reference for the full enterprise AI lifecycle — taxonomy, architecture, security, evaluation, deployment, and specialized systems including RAG and agentic AI.

#	Volume	Intended Reader	What It Delivers
8	Handbook for AI Power Users	Researchers, advanced practitioners, prompt engineers	Advanced prompt engineering for practitioners — chain-of-thought reasoning, hallucination detection, prompt-injection defense, and production prompt management.
9	AI Prompt Desk Guide	All employees, end users, general staff	A plain-language quick reference for writing effective prompts across ChatGPT, Claude, Gemini, and other assistants — usable with no technical background.
10	Understanding and Using AI: A Beginner's Guide	Anyone new to AI with basic computer literacy	A first-day orientation to AI: what it is, how to prompt it, how to protect your data, and how to catch its mistakes.
COMPANION & DERIVED WORKS — Volumes 11–13			
11	AI for Small Business	Small business owners, solo operators, micro-teams	Scales the enterprise frameworks down to solo operators and micro-teams, with worked cases, a five-step adoption playbook, and a right-sized ROI model.
12	On-Demand Implementation Manuals	Authors of internal AI documentation, managers, audit reviewers	Teaches a repeatable workflow for combining this series with an AI assistant to produce customized, audit-defensible implementation documentation.
13	Model Card Operations Manual — SAP HANA + ServiceNow AP	Controllers, internal auditors, finance operations	A worked procedure for creating, reviewing, approving, and maintaining model cards for AI agents in SAP S/4HANA and ServiceNow Accounts Payable environments.

Where to find the series. All volumes are openly available on Zenodo under a Creative Commons Attribution-NonCommercial 4.0 International (CC BY-NC 4.0) license, which permits sharing and adaptation with attribution for non-commercial purposes. The volumes may not be sold or used for commercial purposes. For the complete series map — including recommended reading pathways by role and the full reading sequence — begin with the *Executive Summary and Series Overview*.

Volume titles above are shown in short form for brevity. Each volume's full title, including its subtitle, appears on its own title page and in its Zenodo record.

Copyright and Licensing

© 2026 Harold W. Webb. All rights reserved.

This work is licensed under a Creative Commons Attribution-NonCommercial 4.0 International License (CC BY-NC 4.0). You are free to share and adapt this material for non-commercial purposes, provided appropriate attribution is given. Commercial use requires separate licensing.

To view a copy of this license, visit <https://creativecommons.org/licenses/by-nc/4.0/>.

For commercial licensing inquiries, contact the author at hwebb@ut.edu (ORCID: 0009-0006-2002-2209).

ENTERPRISE AI HANDBOOK SERIES

ABOUT THIS SERIES

A practical, role-based library for adopting, governing, building, and using Enterprise AI. The series connects strategy, governance, management, development, prompting, user enablement, and implementation practice in one coordinated system.

VOLUME 2

ENTERPRISE AI GOVERNANCE HANDBOOK

Written for executives, governance leaders, legal, risk, and compliance teams, this volume translates Enterprise AI governance into practical control structures. It addresses policies, oversight, risk classification, standards mapping, and audit-oriented accountability to help organizations govern AI with confidence.

ABOUT THE AUTHOR

Harold W. Webb, PhD, MBA, is Associate Professor Emeritus of Information and Technology Management at The University of Tampa. He co-authored U.S. Army Research Institute Technical Report 1091 on technology adoption in organizations, research that helps inform this series. He is a former Army officer and holds degrees from Texas Tech University and The University of Alabama.

STRATEGY. GOVERNANCE. OPERATIONS.

HAROLD WEBB, PhD